



CYBERSECURITY

Compliance Audit Report

BeCode Corp. · Secure Network Design

PRIMARY FRAMEWORK

CyFun 2025 (Important)

ASSURANCE LEVEL

Important · CIS IG2

ISSUE DATE

24 April 2026

NIS2 Belgian Act · GDPR · APD/GBA · ISO/IEC 27001:2022 · ISO/IEC 27005:2022 · NIST SP 800-53 Rev. 5 · SOC 2 · Cyber Resilience Act · CIS Controls v8.1 (IG2) · CIS Cisco IOS Benchmark · MITRE ATT&CK

About this report. BeCode Corp. is a fictitious organization. The audited network is a simulated Cisco Packet Tracer lab produced by a separate student team during the BeCode cybersecurity bootcamp. This report is the independent compliance audit of that network and its design document, and is the work of the audit team above. It is written in the format of a real audit for training and portfolio purposes only, with no real organization, system, or personal data involved, which is why it is shared publicly.

AUDIT TEAM

Zoltàn Frenyo · Johan-Emmanuel Hatchi · André Penas

Audit at a glance

CRITICAL
OVERALL POSTURE

18
FINDINGS

1.13_{/3}
CYFUN MATURITY

12
FRAMEWORKS

CYFUN 2025 MATURITY BY FUNCTION

Function	Maturity Score
GOVERN	1.00
IDENTIFY	1.10
PROTECT	1.39
DETECT	1.13
RESPOND	1.00
RECOVER	1.00

Measured 1.13 against a target of 3.0 (dashed). Govern, Respond and Recover sit at the 1.0 floor.

FINDINGS BY SEVERITY

Critical		7
High		10
Medium		1
Low		0

TOP 3 CRITICAL RISKS

CRIT

F-17 Inter-VLAN ACLs defined but never applied, segmentation theoretical

CRIT

F-10 ASA firewall in factory configuration, privileged mode unprotected

CRIT

F-04 No centralized logging or NTP, no NIS2-timely detection

Table of Contents

1. Executive Summary	5
1.1 Context	5
1.2 Overall security posture	5
1.3 The systemic pattern uncovered	5
1.4 Top 3 critical risks	5
1.5 Top 3 immediate recommendations (< 24h)	6
1.6 Overall remediation effort	6
2. Scope and Methodology	7
2.1 Audit scope	7
2.2 BeCode Corp. positioning	7
2.3 Evaluation methodology	7
2.4 Severity scale	7
2.5 Audit limitations	7
3. Compliance frameworks in scope	9
3.1 Applicability table	9
3.2 Why this hierarchy	9
4. Detailed Findings	11
F-01 - Shared administrator secret across the entire scope	11
F-02 - No multi-factor authentication on privileged access	13
F-03 - No privilege segregation - single-level authentication model	14
F-04 - No centralization or correlation of security logs	16
F-05 - No detection capability (anti-malware, IDS/IPS, EDR)	18
F-06 - No backup or recovery mechanism	19
F-07 - No incident response plan	21
F-08 - No vulnerability management or patch management	22
F-09 - Undersized SSH cryptography (RSA 1024-bit keys)	24
F-10 - ASA 5506-X firewall in factory configuration - no authentication, no filtering	26
F-11 - Permissive trunk configuration on SW2 - no VLAN restriction	28
F-12 - Printers not assigned to a dedicated VLAN - systemic flaw across SW1, SW2, SW3	29
F-13 - Native VLAN 1 not purged across trunks	30
F-14 - AAA protocol mismatch - TACACS+ clients vs RADIUS server	31
F-15 - AAA user base with trivial credentials (username = password)	33
F-16 - Undocumented perimeter filtering and FTP in cleartext	34
F-17 - Inter-VLAN ACLs defined but not applied on L3-SW SVIs	35
F-18 - VTY lines 5-15 not hardened on SW1, SW2, SW3 - Telnet access possible by default	38
5. Risk Summary Table	40
6. Remediation Roadmap	41
6.1 Quick wins and immediate actions (< 1 week)	41
6.2 Short term (1 to 3 months)	42
6.3 Long term (6 to 18 months)	43

7. Conclusion	45
7.1 Summary	45
7.2 Current compliance vs CyFun Important target	45
7.3 Strategic recommendations	45
7.4 Closing remarks	45
Annex A - Empirical evidence screenshots	46
Screenshot 1 - ASA show running-config (beginning)	46
Screenshot 2 - ASA show running-config (continuation)	47
Screenshot 3 - ASA show interface ip brief	48
Screenshot 4 - ASA show nat / show access-list / show route	49
Screenshot 5 - L3-SW login + include enable secret / ntp / logging	50
Screenshot 6 - SW1 trunk and Fa0/23 configuration	51
Screenshot 7 - SW1 show interfaces trunk	52
Screenshot 8 - SW3 show interfaces trunk + Fa0/23	53
Additional empirical checks not captured in this iteration	53
Annex B - CyFun 2025 Self-Assessment Toolbox	54
File	54
Content	54
Relation to this report	54
How to read it	54

1. Executive Summary

1.1 Context

This audit assesses compliance of the Secure Network Design - BeCode Corp. project against the CyberFundamentals Framework 2025 (Important level) issued by the Centre for Cybersecurity Belgium (CCB), with multi-framework anchoring to NIS2, GDPR, ISO/IEC 27001:2022, ISO/IEC 27005:2022, NIST SP 800-53 Rev. 5, SOC 2, Cyber Resilience Act, CIS Controls v8.1, MITRE ATT&CK, and the Belgian Data Protection Authority (APD/GBA) guidelines.

This is a hybrid audit combining documentary analysis (paper audit) and direct empirical verification on the Cisco Packet Tracer file via CLI. Eight screenshots are embedded in Annex A and factually support the most serious findings; the remaining empirical checks are documented as CLI transcripts inside each finding's Evidence section. The CyFun 2025 Self-Assessment Toolbox (official CCB workbook) is delivered as Annex B and supports every CyFun score cited throughout this report.

1.2 Overall security posture

The overall security posture of the design is assessed as **CRITICAL**.

18 findings were identified: 7 Critical, 10 High, 1 Medium, 0 Low. Empirical verification revealed major gaps between documentary claims and technical reality.

1.3 The systemic pattern uncovered

The most structurally important finding of this audit is not technical - it is organizational. Four separate findings point to the same root cause: a disconnect between what the deliverable claims and what the actual configuration implements:

- F-10: ASA 5506-X claimed as perimeter firewall → full factory configuration, Internet interface shutdown, privileged mode with no password.
- F-14: TACACS+ AAA claimed for centralized authentication → server actually configured in RADIUS, incompatible protocols, only local fallback operates.
- F-17: Inter-VLAN ACLs explicitly documented in §13.6.1 → none applied on L3-SW SVIs, inter-VLAN segmentation inoperative.
- F-18: Hardened VTY lines (transport input ssh) documented → only vty 0-4 are hardened, vty 5-15 remain permissive across the 3 access switches.

This documentation/implementation disconnect is a process defect (absence of final review) that is more severe than any individual finding. The report recommends as its top priority a full audit of all §10.1 claims in the deliverable to detect additional gaps.

1.4 Top 3 critical risks

- **F-17 - Inter-VLAN ACLs not applied: the claimed segmentation is theoretical. A PC in the Study VLAN can freely reach servers or the management VLAN.**
- **F-10 - ASA firewall in factory configuration: privileged mode without password, no filtering, Internet interface disabled.**
- **F-04 - No centralized logs and no NTP: inability to detect or notify an incident within NIS2 deadlines.**

1.5 Top 3 immediate recommendations (< 24h)

1. Apply the 7 ACLs to the corresponding L3-SW SVIs (ip access-group ACL_V10_MGMT in, etc.). Effort: 5 minutes. Impact: immediate restoration of inter-VLAN segmentation.
2. Set a strong enable secret on the ASA and document credentials. Effort: 10 minutes. Impact: closure of privileged mode without authentication.
3. Export the 5 device configurations to secure storage (copy running-config tftp:). Effort: 15 minutes. Impact: guaranteed rebuild in case of destructive incident.

1.6 Overall remediation effort

- Quick wins (< 1 week, low effort): ~25 immediately applicable actions, mainly configuration changes.
- Short term (1-3 months, medium effort): ~27 actions requiring acquisition of standard tools (syslog, antivirus, backup, IR plan, corrected AAA).
- Long term (6-18 months, high effort): ~20 strategic actions (SIEM, PAM, MFA, BCP/DRP, vulnerability management program).

Indicative budget: €30,000 to €80,000 for short-term actions depending on tool choices (open source vs commercial). Reaching CyFun Important level is realistic in 6 to 12 months with strong management commitment.

2. Scope and Methodology

2.1 Audit scope

Provenance and attribution. The audited deliverable, a 44-page network design document and its Cisco Packet Tracer file, was produced by a separate BeCode student team during the same bootcamp. This report is the independent compliance audit of that material. The audit, the 18 findings, and this document are the work of the audit team named on the cover.

The audit covers the Secure Network Design - BeCode Corp. deliverable (44 pages) AND the associated Cisco Packet Tracer file (NetworkProject.pkt). Auditors had direct CLI access to all devices.

Included: network architecture, declared AND actual configurations via CLI, documented security measures, compliance claims in chapter 10.

Excluded: operational aspects not observable in simulation (business processes, security culture, effective governance), intrusive tests, audit of endpoints and application servers.

2.2 BeCode Corp. positioning

The project does not specify BeCode Corp.'s sector or size. The organization is positioned as a tertiary-sector SME/mid-sized company (>50 employees), not explicitly listed in Annex I of the Belgian NIS2 Act but potentially covered by Annex II (Important entity).

The CyFun Important assurance level is retained. CIS references are calibrated on Implementation Group 2 (IG2).

2.3 Evaluation methodology

1. Documentary analysis of the deliverable (44 pages).
2. CyFun scoring via official CCB CyFun 2025 Toolbox (Important level, 6 functions: GOVERN/IDENTIFY/PROTECT/DETECT/RESPOND/RECOVER). The completed workbook is delivered as Annex B.
3. Direct empirical verification on the Packet Tracer file: show running-config, show interfaces trunk, show ip interface brief, show version, show nat, show access-list, show route, show cdp neighbors commands, inspection of AAA, FTP, DNS, DHCP services.
4. Consolidation into 18 narrative findings with localized evidence (PDF page or CLI screenshot), risk analysis, multi-framework regulatory mapping, MITRE ATT&CK technique mapping, severity rationale, remediation plan by time horizon.

2.4 Severity scale

Severity	Definition	Remediation timeline
Critical	Immediate exploitability, systemic impact, direct legal non-compliance.	Immediate - 7 days max
High	Exploitable risk under realistic conditions, no compensating controls.	30 to 90 days
Medium	Risk under specific conditions, limited impact.	3 to 6 months
Low	Minor gap, low exploitability.	As time permits

2.5 Audit limitations

- Simulated environment: Packet Tracer does not simulate certain services (HTTP server, finger, BOOTP). Related findings were discarded.

- Documentary + CLI scope: the audit does not include interviews with the designers. Some intents may have been misinterpreted.
- Tools: commercial automated audit tools (PingCastle, Nessus) not applicable to Packet Tracer.

3. Compliance frameworks in scope

This audit mobilizes 12 frameworks, organized in three levels of hierarchy. Each finding is mapped to the relevant frameworks only - the number of references varies with the nature of the finding. This approach avoids filler and preserves readability in defense.

3.1 Applicability table

Framework	Applicability	Role in this audit
CyFun 2025 (Important)	Primary	Structuring framework of the audit (6 CSF functions). Scored via official CCB Toolbox.
NIS2 - Belgian Act 26/04/2024	Legal applicable	Belgian transposition of EU Directive 2022/2555. Art. 21 (measures) and Art. 23 (notification) obligations.
GDPR	Legal applicable	EU Regulation 2016/679. Art. 32 (processing security) and Art. 33-34 (breach notification).
APD / GBA	Belgian authority	Belgian Data Protection Authority. National guidelines on authentication and breach handling.
ISO/IEC 27001:2022	ISMS reference	International ISMS standard. Annex A (93 controls) mapped on technical findings.
ISO/IEC 27005:2022	Risk management	Information risk management methodology. Referenced on findings related to risk analysis.
NIST SP 800-53 Rev. 5	Control catalog	US federal control catalog widely used as baseline reference outside the federal scope. Cross-mapped with CyFun and ISO 27001.
SOC 2 (AICPA)	Voluntary	Trust Services Criteria. Relevant if BeCode Corp. provides SaaS services to US clients.
Cyber Resilience Act (CRA)	Indirect impact	EU Regulation 2024 on products with digital elements. BeCode Corp. = user. Generates obligations toward suppliers (SBOM, patches ≥ 5 years).
CIS Controls v8.1 (IG2)	Technical best practice	Center for Internet Security. 18 controls, 153 safeguards. Detailed reference for technical findings.
CIS Cisco IOS Benchmark	Technical guide	~300 pages of Cisco IOS hardening recommendations. Referenced on network configuration findings.
MITRE ATT&CK	Threat framework	Adversary tactics and techniques. Used to link each technical finding to documented real-world exploitation paths.
eIDAS 2.0	Not applicable	EU Regulation on electronic identity, EU Digital Wallet, QTSP. The project contains no qualified electronic identity service.

3.2 Why this hierarchy

The multi-framework mapping pursues 4 objectives:

- Legal traceability: each technical finding maps to an enforceable legal requirement (NIS2, GDPR).
- Audit defense: when facing an external auditor (ISO, SOC), cross-references strengthen the credibility of the observation.
- Technical actionability: CIS Benchmarks and NIST SP 800-53 provide precise remediation guidance (which regulations do not).

- Threat relevance: MITRE ATT&CK links each finding to documented attacker techniques, moving the narrative from "compliance gap" to "concrete attack path".

Each finding cites 7 to 15 references on average depending on its scope, each chosen to contribute unique information (no redundancy).

4. Detailed Findings

This section presents the 18 findings with full regulatory mapping and, where applicable, MITRE ATT&CK technique mapping. Each finding includes a 3-column table cross-referencing framework, precise reference and corresponding requirement, plus a separate MITRE ATT&CK table explaining how the finding relates to documented adversary behavior.

F-01 - Shared administrator secret across the entire scope

CRITICAL

EVIDENCE

Document §13.10.1 and §13.10.2:

```
enable secret cisco@123!  
username admin secret cisco@123!  
tacacs-server key cisco@123!
```

Empirical verification on L3-SW:

```
L3-SW#show running-config | include enable secret  
enable secret 5 $1$mERr$UDABLB/uC5.9xZ0BcpF5U.
```

AAA server screenshot: shared key cisco@123! identical across the 4 clients (L3-SW, SW1, SW2, SW3).

OBSERVATION

A single static weak secret combines five distinct uses across five devices. No password policy, no rotation, no centralized secret vault.

The enable secret hash is Type 5 (MD5 + short salt), deprecated since 2012. Crackable in seconds with hashcat for a trivial password such as cisco@123!.

RISK

Compromise of a single device exposes the entire scope:

- Simultaneous admin authentication across 5 devices.
- ACL modification and segmentation bypass.
- Persistence through local account creation.
- Logging disabled and traces wiped.

The password cisco@123! appears in public Cisco-default brute-force dictionaries.

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	PR.AA-01.2 (score 1)	Identities and credentials managed securely
CyFun 2025 Important	PR.AA-05.4 (score 1)	No admin privileges for routine tasks
NIS2 Belgian Act (26 April 2024)	Art. 21(2)(i)	Multi-factor authentication on privileged accounts
GDPR	Art. 32(1)(b)	Confidentiality, integrity, resilience of systems
APD / GBA	2023 Authentication Guidelines	MFA strongly recommended for administrators
ISO/IEC 27001:2022	Annex A 5.17	Authentication information
ISO/IEC 27001:2022	Annex A 8.5	Secure authentication
ISO/IEC 27005:2022	§8.2	Risk assessment - threat identification
NIST SP 800-53 Rev. 5	AC-2 / IA-5 / IA-5(1)	Account management and authenticator management
SOC 2	CC6.1 / CC6.2	Logical access controls and credential management
CIS Controls v8.1	Safeguard 5.2 (IG1)	Use unique passwords (≥ 14 characters)
CIS Controls v8.1	Safeguard 6.5 (IG2)	MFA for administrative access
CIS Cisco IOS Benchmark	§1.1.1	Unique passwords per device

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
T1078	Valid Accounts	A single leaked secret grants legitimate admin access to the whole infrastructure, bypassing detection controls.
T1110.002	Password Cracking	Type 5 (MD5) hash of a dictionary password is crackable offline in seconds using hashcat.

SEVERITY RATIONALE

Immediate exploitability, maximum impact surface, weak hash quickly crackable, direct empirical evidence. No compensating control.

REMEDIATION

Quick wins (< 1 week)

1. Generate a unique password per device (≥ 14 characters), stored in a secret vault.
2. Replace Type 5 with Type 9 (scrypt): enable algorithm-type scrypt secret <password>.
3. Rename the admin account (e.g. netadm-sw1) to prevent enumeration.
4. Generate a distinct TACACS+ key, unique per device/AAA server pair.

Short term (1-3 months)

1. Deploy a secret vault (HashiCorp Vault, CyberArk).
2. Define a password policy (length, quarterly rotation, complexity).

3. Enable full authentication audit on the AAA server.

Long term (3-12 months)

1. MFA on all administrative access.
2. Automated secret rotation via vault.

F-02 - No multi-factor authentication on privileged access

CRITICAL

EVIDENCE

Document §13.10: authentication based solely on username + static password.

Empirical verification: connection to L3-SW obtained with user-a/user-a (login) then cisco@123! (enable) - no second factor at any stage.

OBSERVATION

No second factor required. Access relies exclusively on a username/password pair.

Worsened by F-01 (shared secret) and F-15 (username = password): compromise of the single factor opens the entire scope.

RISK

Standard initial compromise vectors:

- Targeted phishing capturing admin credentials.
- Credential stuffing from a public breach.
- Keylogger on a compromised admin workstation.

NIS2 Art. 21(2)(i) explicitly mandates MFA on privileged access for Important entities.

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	PR.AA-03.2 (score 1)	Multi-factor authentication
NIS2 Belgian Act	Art. 21(2)(i)	MFA - explicit requirement
APD / GBA	2024 Security Recommendation	MFA on access to personal data
ISO/IEC 27001:2022	Annex A 8.5	Secure authentication
NIST SP 800-53 Rev. 5	IA-2(1) / IA-2(2)	MFA for privileged and non-privileged accounts
SOC 2	CC6.1	Logical and physical access controls
CIS Controls v8.1	Safeguard 6.4 (IG1)	MFA for remote network access
CIS Controls v8.1	Safeguard 6.5 (IG2)	MFA for administrative access
ANSSI	Hygiene Guide §10	Strong authentication for administration

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
T1078	Valid Accounts	Absence of MFA means any stolen credential grants full access without secondary challenge.

SEVERITY RATIONALE

Direct non-compliance with NIS2 Art. 21(2)(i). Explicit legal requirement. Total impact surface combined with F-01 and F-15.

REMEDIATION

Quick wins (< 1 week)

- 1. Restrict source IPs allowed to initiate SSH (harden management VLAN 99 ACL).

Short term (1-3 months)

- 1. MFA-capable RADIUS server (FreeRADIUS + Duo, Cisco ISE).
- 2. Delegate authentication to MFA with local fallback only during network outage.
- 3. Train admins on MFA enforcement.

Long term (6-12 months)

- 1. Administrative bastion with MFA and session recording.
- 2. Integration with organizational IdP.

F-03 - No privilege segregation - single-level authentication model

HIGH

EVIDENCE

Empirical verification: authentication works in two stages:

STEP 1 - User login (AAA base): Username: user-a Password: user-a Username: user-b Password: user-b Username: user-c Password: user-c STEP 2 - Enable (privileged mode): Password: cisco@123! (shared secret identical on SW1, SW2, SW3, L3-SW, R1)

The 3 users enter privileged mode with the same secret. No intermediate privilege level (Cisco privilege level 0-15) is defined.

No effective TACACS+ accounting configuration (see F-14 - TACACS+ inoperative).

OBSERVATION

Binary model: either the user knows cisco@123! and has full powers, or has no access. No read-only operator role, no junior-admin role, no super-admin.

The 3 users (user-a, user-b, user-c) are functionally identical once in privileged mode. No segregation.

The enable secret is shared and documented (§13.10): anyone with access to the documentation and a user login can potentially reach admin mode.

RISK

Direct consequences:

- Targeted revocation impossible: if user-a leaves, the enable secret remains known.

- Individual traceability broken: all users are admins, making it impossible to formally identify the author of a destructive action in privileged mode.
- Incompatible with Separation of Duties (SoD) required by any serious audit.
- Human error amplified: any user in privileged mode can impact production (erased config, VLAN outage).

NIS2 Art. 21(2)(i) requires privileged access management - this model cannot support it.

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	PR.AA-05.4 (score 1)	No admin privileges for routine tasks
CyFun 2025 Important	PR.AA-05.6 (score 1)	Separation of duties (SoD)
CyFun 2025 Important	PR.AA-05.7 (score 1)	Privileged users managed and monitored
NIS2 Belgian Act	Art. 21(2)(i)	Privileged access management
ISO/IEC 27001:2022	Annex A 5.15	Access control
ISO/IEC 27001:2022	Annex A 8.2	Privileged access rights
NIST SP 800-53 Rev. 5	AC-5 / AC-6 / AC-6(5)	Separation of duties and least privilege for privileged accounts
SOC 2	CC6.3	User access - segregation of duties
CIS Controls v8.1	Safeguard 5.4 (IG1)	Restrict administrator privileges to dedicated accounts
CIS Controls v8.1	Safeguard 6.8 (IG2)	Define and maintain role-based access control
CIS Controls v8.1	Safeguard 8.5 (IG2)	Collect detailed audit logs on admin actions

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
T1078.003	Valid Accounts: Local Accounts	Shared enable secret means any compromised local user effectively gains admin privileges.

SEVERITY RATIONALE

High: insider risk requiring initial access, but the combination with F-01, F-02 and F-15 makes this a systemic finding.

REMEDIATION

Quick wins (< 1 week)

1. Create individual named accounts for each admin.
2. Remove or restrict use of the generic admin account.
3. Enable TACACS+ accounting (after F-14 remediation) on all devices.

Short term (1-3 months)

1. Differentiated Cisco IOS privilege levels (0-15) to separate read/config access.
2. Documented RACI matrix.
3. Quarterly review of privileged access.

Long term (6-12 months)

1. PAM solution (CyberArk, BeyondTrust).
2. Video recording of critical sessions.

F-04 - No centralization or correlation of security logs**CRITICAL****EVIDENCE**

Document §12: syslog listed as a "future improvement". No syslog server in §3.1 or §6.

Empirical verification on L3-SW:

```
L3-SW#show running-config | include ntp
L3-SW#show running-config | include logging
L3-SW#
```

Both commands return EMPTY: no logging host, no ntp server, no service timestamps.

OBSERVATION

The design provides no mechanism for centralizing, retaining or correlating logs. Logs remain in volatile memory with no persistence.

Confirmed absence of NTP: timestamps are unsynchronized across devices, cross-device correlation is impossible.

RISK

The organization is structurally unable to:

- Detect an ongoing incident.
- Investigate post-incident (forensics impossible).
- Meet NIS2 notification obligations (24h/72h/1 month).
- Identify slow attack patterns (APT, lateral movement).

This finding makes it impossible to detect compromises arising from F-01 through F-03.

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	PR.PS-04.1 (score 2)	Logs maintained, documented, monitored
CyFun 2025 Important	PR.PS-04.2 (score 1)	Authoritative timestamps
CyFun 2025 Important	DE.AE-03.1 (score 2)	Information correlated from multiple sources
NIS2 Belgian Act	Art. 21(2)(b)	Incident detection and handling
NIS2 Belgian Act	Art. 23	Notification obligations
GDPR	Art. 33	Breach notification within 72h
APD / GBA	Processing activities register	Incident documentation required
ISO/IEC 27001:2022	Annex A 8.15	Logging
ISO/IEC 27001:2022	Annex A 8.16	Monitoring activities
ISO/IEC 27001:2022	Annex A 8.17	Clock synchronization
NIST SP 800-53 Rev. 5	AU-2 / AU-3 / AU-6 / AU-8 / AU-12	Event logging, audit content, review, timestamps, generation
SOC 2	CC7.2	System monitoring
CIS Controls v8.1	Safeguard 8.2 (IG1)	Collect audit logs
CIS Controls v8.1	Safeguard 8.4 (IG2)	Standardize time synchronization (NTP)
CIS Controls v8.1	Safeguard 8.9 (IG2)	Centralize audit logs
CIS Controls v8.1	Safeguard 8.11 (IG2)	Conduct audit log reviews

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
T1070	Indicator Removal	Without centralized logs, an attacker can erase local device logs with no off-box copy to reconstruct activity.
T1562.001	Impair Defenses: Disable or Modify Tools	Local-only logging means tampering leaves no forensic trail.

SEVERITY RATIONALE

Maximum severity: blocks detection, investigation AND regulatory notification. Direct empirical evidence.

REMEDIATION

Quick wins (< 1 week)

1. Configure NTP on all devices (ntp server or internal server).
2. Enable local logging with maximum retention and ISO 8601 timestamps (service timestamps log datetime msec show-timezone).

Short term (1-3 months)

1. Centralized syslog server (rsyslog, Graylog) in Servers VLAN.
2. logging host on all devices, informational level.
3. Retention policy (minimum 6 months, 12 months recommended for NIS2).

4. Redundant internal stratum-2 NTP server.

Long term (6-18 months)

1. SIEM (Splunk, Elastic, Wazuh, Sentinel).
2. Monitoring runbook (thresholds, escalation, SLA).
3. Integration with internal or outsourced SOC.

F-05 - No detection capability (anti-malware, IDS/IPS, EDR)

HIGH

EVIDENCE

Document §3.1, §7, §9: no mention of antivirus, EDR, IDS, IPS.

§12 (Future Improvements) lists IDS/IPS as a future enhancement.

OBSERVATION

Design relies only on perimeter prevention (firewall) and segmentation (VLAN + ACLs - see F-17 for the enforcement gap).

In Defense in Depth, all endpoint, application and data layers are missing.

RISK

An attacker past the perimeter will operate unhindered:

- No detection of malicious execution on endpoints.
- No detection of inter-VLAN lateral movement.
- No detection of FTP exfiltration.
- No alert on standard techniques (pass-the-hash, Kerberoasting).

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	DE.CM-01.2 (score 1)	Anti-virus/malware
CyFun 2025 Important	DE.CM-03.1 (score 1)	Endpoint/network protection
NIS2 Belgian Act	Art. 21(2)(b)	Incident management
ISO/IEC 27001:2022	Annex A 8.7	Protection against malware
NIST SP 800-53 Rev. 5	SI-3 / SI-4	Malicious code protection and system monitoring
SOC 2	CC7.1	System detection - malware
CIS Controls v8.1	Control 10 (IG1)	Malware defenses
CIS Controls v8.1	Control 13 (IG2)	Network monitoring and defense
CIS Controls v8.1	Safeguard 13.3 (IG2)	Network intrusion detection

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
TA0005	Defense Evasion (broad)	Entire tactic category is uncovered: no endpoint or network sensors to observe indicators such as T1059 scripting, T1055 process injection, T1105 ingress tool transfer.

SEVERITY RATIONALE

Total absence of detection layers. Not Critical because compensable via deployment of standard products.

REMEDIATION

Quick wins (< 1 week)

1. Enable native IOS features: IP Source Guard, DHCP Snooping, Dynamic ARP Inspection.

Short term (1-3 months)

1. EDR on endpoints (Defender, CrowdStrike, SentinelOne).
2. Network IDS sensor (Suricata, Snort, Zeek) on SPAN port of L3-SW.
3. Netflow on R1.

Long term (6-18 months)

1. Integrate IDS/EDR alerts into SIEM.
2. Proactive threat hunting.

F-06 - No backup or recovery mechanism

CRITICAL

EVIDENCE

Document: no backup section. No backup server in the §3.1 inventory.

No archive path or kron occurrence command documented in §13.

OBSERVATION

No mechanism in place to back up: network configurations (5 devices), FTP data, AAA databases, internal DNS records.

No recovery procedure, no test, no DRP.

RISK

In the event of a major incident (ransomware, hardware failure, human error):

- Manual rebuild of configurations (several days).
- Permanent loss of FTP data.
- Loss of AAA base (accounts and rights).

Ransomware was the #1 cyber incident cause in Belgium in 2025 (CCB).

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	PR.DS-11.1 (score 1)	Backups performed
CyFun 2025 Important	RC.RP-01.1 (score 1)	Recovery process defined
NIS2 Belgian Act	Art. 21(2)(c)	Business continuity and crisis management
GDPR	Art. 32(1)(c)	Restore availability in a timely manner
ISO/IEC 27001:2022	Annex A 8.13	Information backup
ISO/IEC 27001:2022	Annex A 5.29	Information security during disruption
ISO/IEC 27001:2022	Annex A 5.30	ICT readiness for business continuity
ISO/IEC 27005:2022	§8.4	Risk treatment - continuity
NIST SP 800-53 Rev. 5	CP-9 / CP-10	System backup and recovery
SOC 2	A1.2	Availability - data backup
Cyber Resilience Act	Annex I §1(3)(k)	Provide recovery to secure state
CIS Controls v8.1	Control 11 (IG1)	Data recovery
CIS Controls v8.1	Safeguard 11.2 (IG1)	Automated backups
CIS Controls v8.1	Safeguard 11.3 (IG1)	Protect recovery data (offline/offsite)
CIS Controls v8.1	Safeguard 11.5 (IG2)	Test data recovery

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
T1490	Inhibit System Recovery	Absence of backups means any destructive action - ransomware, wiper, or accidental erasure - results in permanent data loss without recovery option.

SEVERITY RATIONALE

Maximum severity: multiplies business impact of any destructive incident by 10. Direct NIS2 non-compliance.

REMEDIATION

Emergency action (< 24h)

1. Manually export (copy running-config tftp:) configs of the 5 devices. IMMEDIATELY.

Quick wins (< 1 week)

1. Document the manual recovery procedure.
2. Set up a versioned Git repository for backed-up configurations.

Short term (1-3 months)

1. Backup server (Veeam, Bacula) in Servers VLAN.
2. Daily automated backup via TFTP/SCP.
3. Encrypted FTP and AAA backups (3-2-1 rule).
4. Documented quarterly restore test.

Long term (6-12 months)

1. Formal BCP/DRP with RTO/RPO.
2. Annual DRP test under real conditions.
3. Immutable offline backups (WORM, air-gap) against ransomware.

F-07 - No incident response plan**HIGH****EVIDENCE**

No IR section in the deliverable. CyFun RS.* and RC.* controls all scored 1.

OBSERVATION

No IR plan, no triage, no communication channel to CCB/CERT.be, no containment procedure.

RISK

Improvised and delayed reaction:

- Breach of NIS2 deadlines (24h early warning, 72h full report, 1 month final).
- Breach of GDPR Art. 33 (72h).
- Loss of forensic evidence through disorganized actions.
- Incident expansion due to absence of containment.

NIS2 Important sanctions: up to €7M or 1.4% of annual turnover.

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	RS.MA-01.1 (score 1)	IR plan executed
CyFun 2025 Important	RS.CO-02.1 (score 1)	Internal and external communication
NIS2 Belgian Act	Art. 23	Notification 24h/72h/1 month
GDPR	Art. 33	Breach notification within 72h
GDPR	Art. 34	Communication to data subjects
APD / GBA	Breach notification form	Belgian notification channel
ISO/IEC 27001:2022	Annex A 5.24 to 5.28	Information security incident management
NIST SP 800-53 Rev. 5	IR-4 / IR-6 / IR-8	Incident handling, reporting, response plan
SOC 2	CC7.3 / CC7.4	Incident response
CIS Controls v8.1	Control 17 (IG1)	Incident response management
CIS Controls v8.1	Safeguard 17.4 (IG1)	Incident response process

SEVERITY RATIONALE

High: latent risk but becomes Critical in a real incident situation.

REMEDIATION**Quick wins (< 1 week)**

1. Named IR responsible (primary + backup).

2. Paper emergency booklet: CERT.be (+32 2 790 33 33), CCB, APD, internal contacts.
3. Register with the CERT.be portal.

Short term (1-3 months)

1. Structured IR plan per NIST SP 800-61r2 (Preparation/Detection/Containment/Eradication/Recovery/Lessons).
2. Incident classification matrix (Low → Critical).
3. Formalized external notification process (CCB, CERT.be, APD).

Long term (6-12 months)

1. Annual cyber crisis tabletop exercise.
2. Team training in basic forensics.
3. External IR provider retainer.

F-08 - No vulnerability management or patch management

HIGH

EVIDENCE

Document: no dedicated section. CyFun scores ID.AM-08.2 = 1, ID.RA-01.* = 1-2.

OBSERVATION

No process for IOS firmware, server OS, workstation OS, ASA firewall.

No vulnerability scanner, no CTI feed subscription (Cisco PSIRT, CCB, CERT.be).

RISK

- IOS firmware affected by exploitable CVEs (e.g. CVE-2023-20198 IOS XE - unauthenticated RCE).
- Unpatched servers exposed to public exploits.
- 60% of compromises use known vulnerabilities > 12 months old (Verizon DBIR 2024).

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	ID.AM-08.2 (score 1)	Patches and security updates
CyFun 2025 Important	ID.RA-01.* (score 1-2)	Vulnerability identification and management
CyFun 2025 Important	ID.RA-08.1 (score 1)	Vulnerability disclosure
NIS2 Belgian Act	Art. 21(2)(e)	Security in acquisition/development/maintenance
GDPR	Art. 32(1)(d)	Testing, assessing and evaluating
ISO/IEC 27001:2022	Annex A 8.8	Management of technical vulnerabilities
ISO/IEC 27005:2022	§8.2	Risk identification - vulnerabilities
NIST SP 800-53 Rev. 5	RA-5 / SI-2	Vulnerability monitoring and flaw remediation
SOC 2	CC7.1	Configuration management
Cyber Resilience Act	Annex I §2(1)(2)	Vulnerability handling requirements for products
Cyber Resilience Act	Art. 13	SBOM obligation and security updates ≥ 5 years for manufacturers
CIS Controls v8.1	Control 7 (IG1)	Continuous vulnerability management
CIS Controls v8.1	Safeguard 7.3 (IG1)	Automated OS patch management
CIS Controls v8.1	Safeguard 7.5 (IG2)	Automated vulnerability scans

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
T1190	Exploit Public-Facing Application	Unpatched perimeter devices (e.g. ASA) are direct targets for public-facing exploits.
T1068	Exploitation for Privilege Escalation	Local unpatched kernels and IOS versions enable post-foothold escalation.

SEVERITY RATIONALE

High: very high probabilistic risk (public CVEs). CRA requires the buyer to demand these guarantees from suppliers.

REMEDIATION

Quick wins (< 1 week)

1. Subscribe to Cisco PSIRT, CCB, CERT.be feeds.
2. Inventory of firmware versions vs stable releases.

Short term (1-3 months)

1. Patch management process (monthly cycle + 7-day emergency for critical CVEs).
2. Vulnerability scanner (OpenVAS, Nessus, Qualys) - monthly scan.
3. Tracking table with CVSS severity-based SLA.

Long term (6-12 months)

1. Automated patch deployment (WSUS, Ansible, SCCM).
2. Public CVD program per ID.RA-08.
3. SBOM requirements on suppliers (CRA Art. 13 obligation).

F-09 - Undersized SSH cryptography (RSA 1024-bit keys)**HIGH****EVIDENCE**

Document §13.10.1 and §13.10.2:

```
crypto key generate rsa: 1024
ip ssh version 2

crypto key generate rsa modulus 1024
```

Used on SW1, SW2, SW3, L3-SW, R1.

OBSERVATION

1024-bit modulus, deprecated since 2013 by NIST (SP 800-131A). Cisco IOS supports up to 4096 bits with no operational impact.

No restriction on SSH algorithms: legacy weak ciphers (aes128-cbc, hmac-sha1) accepted by default.

RISK

- Harvest-now-decrypt-later: capture today, decrypt later (documented ANSSI threat).
- Systematic audit non-compliance.
- NIS2 Art. 21(1) requires state-of-the-art measures. Crypto deprecated for 13 years does not qualify.

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	PR.PS-01.1	Secure configuration baseline
CyFun 2025 Important	PR.DS-01.1	Confidentiality/integrity in transit
NIS2 Belgian Act	Art. 21(1)	State-of-the-art measures
NIS2 Belgian Act	Art. 21(2)(h)	Cryptography policies and procedures
GDPR	Art. 32(1)(a)	Encryption of personal data
ISO/IEC 27001:2022	Annex A 8.24	Use of cryptography
NIST SP 800-53 Rev. 5	SC-8 / SC-12 / SC-13	Transmission protection, key management, cryptographic protection
SOC 2	CC6.7	Transmission of data - encryption
Cyber Resilience Act	Annex I §1(3)(e)	Protect data in transit (confidentiality)
NIST SP 800-131A Rev. 2	Table 1	RSA $\geq$ 2048 bits (1024 disallowed)
ANSSI	RGS B1	RSA minimum 2048, recommended 3072 by 2030
CIS Cisco IOS Benchmark	§3.1.3	crypto key generate rsa modulus 2048 minimum
CIS Controls v8.1	Safeguard 3.10 (IG2)	Encrypt sensitive data in transit

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
T1040	Network Sniffing	Captured SSH traffic today can be decrypted later once RSA-1024 is practically breakable (harvest-now-decrypt-later).
T1557	Adversary-in-the-Middle	Weak key size and permissive cipher negotiation enable downgrade attacks on the admin channel.

SEVERITY RATIONALE

High: deprecation documented for 13 years, surface = entire administrative channel, no compensating control.

REMEDIATION

Quick wins (< 1 week)

1. Regenerate RSA keys 2048+ (3072 recommended): crypto key zeroize rsa then crypto key generate rsa modulus 2048.
2. Restrict SSH algorithms: minimum aes256-ctr, hmac-sha2-512, diffie-hellman-group14-sha256.
3. Verify SSHv2 only.

Short term (1-3 months)

1. Organizational cryptographic policy aligned with ANSSI/BSI.
2. Annual key rotation, mandatory at each admin departure.

Long term (12+ months)

1. Post-quantum migration (NIST PQC: Kyber, Dilithium) - roadmap by 2030.

F-10 - ASA 5506-X firewall in factory configuration - no authentication, no filtering

CRITICAL

EVIDENCE

Direct empirical verification on FIREWALL via CLI:

1. Privileged mode access obtained with EMPTY password. No enable secret configured.
2. show running-config reveals:

```
ASA Version 9.6(1)
hostname ciscoasa          ← default hostname
interface GigabitEthernet1/1
  no nameif                 ← no zone
  no security-level         ← no level
  ip address 192.168.20.10 255.255.255.252
interface GigabitEthernet1/2
  no nameif
  no security-level
  no ip address
  shutdown                  ← Internet interface DOWN
```

3. show nat: empty. show access-list: 0 custom ACLs. show route: "Gateway of last resort is not set".
4. show version: "Configuration has not been modified since last system restart".

OBSERVATION

The firewall claimed in §3.1 and §4 is physically present but has NEVER been provisioned:

- No privileged mode authentication.
- No nameif / security-level → inspection engine inert.
- Internet interface administratively down.
- No NAT, no ACL, no route.

The ASA is physically cabled but logically absent from the security path.

RISK

Factual gap between documentary claim and technical reality:

- Misleading impression of compliance.
- NIS2 Art. 21(1) "state-of-the-art" claim cannot be supported.
- Privileged mode without authentication on a device presented as critical.
- Gi1/2 shutdown means Internet traffic does not transit through the firewall.

Combined with F-04, the organization is both DEFENSELESS and BLIND.

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	PR.IR-01.1 (score 1)	Firewalls installed, configured, actively maintained
CyFun 2025 Important	PR.IR-01.4	Boundary protection measures
CyFun 2025 Important	PR.AA-01.2	Credentials managed (total absence on ASA)
NIS2 Belgian Act	Art. 21(1)	State-of-the-art measures
NIS2 Belgian Act	Art. 21(2)(e)	Network security
NIS2 Belgian Act	Art. 21(2)(i)	Privileged access control
ISO/IEC 27001:2022	Annex A 8.20	Networks security
ISO/IEC 27001:2022	Annex A 8.22	Segregation of networks
NIST SP 800-53 Rev. 5	SC-7 / AC-17	Boundary protection and remote access
SOC 2	CC6.6	Boundary protection
Cyber Resilience Act	Annex I §1(3)(a)	Products security by default
CIS Controls v8.1	Safeguard 4.4 (IG1)	Implement and manage a firewall
CIS Controls v8.1	Safeguard 12.2 (IG2)	Secure network architecture

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
T1133	External Remote Services	An unprovisioned perimeter firewall offers no segmentation between internal and Internet-facing segments once Gi1/2 is brought up.
T1078	Valid Accounts	Empty enable secret on the firewall means anyone with CLI access has full admin privileges.

SEVERITY RATIONALE

IRREFUTABLE factual evidence. Design/implementation gap demonstrated. Privileged mode without authentication.

REMEDIATION

Emergency action (< 24h)

1. Set a strong enable secret: enable algorithm-type scrypt secret <password>.
2. Keep Gi1/2 shutdown pending full configuration.

Quick wins (< 1 week)

1. Minimum config: nameif inside (security-level 100) on Gi1/1, nameif outside (security-level 0) on Gi1/2, dynamic NAT.
2. OUTSIDE_IN ACL with default-deny + explicit exceptions.
3. Default route to ISP.
4. Document ASA credentials in the secret vault.

Short term (1-3 months)

1. Per-service filtering rules, application inspection, syslog logging, SNMPv3.
2. DMZ creation for FTP.

Long term (6-12 months)

1. Evaluate ASA 5506-X replacement (End-of-Sale August 2022 - CRA requires ongoing support).

F-11 - Permissive trunk configuration on SW2 - no VLAN restriction**HIGH****EVIDENCE**

Empirical verification on SW2:

```
SW2#show running-config | section interface GigabitEthernet0/1
interface GigabitEthernet0/1
switchport mode trunk
```

Absence of the 3 hardening commands: switchport trunk allowed vlan, native vlan, nonegotiate.

Comparison with SW1 and SW3 (verified): both correctly apply switchport trunk allowed vlan 1,10,20,30,40,50,60,70,99. SW2 is the isolated weak point.

OBSERVATION

Gi0/1 on SW2 accepts all 4094 VLANs. DTP active in implicit dynamic auto (trunk negotiable from an access port).

RISK

- VLAN hopping via double-tagging: inject 802.1Q double-tagged frames toward VLAN 99 (management) or VLAN 70 (servers).
- Switch spoofing via DTP.
- Bypass of inbound ACLs on SVIs - hopped traffic bypasses the L3-SW.

This finding partially neutralizes the segmentation claimed in §9.

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	PR.IR-01.2	Effective network segmentation
NIS2 Belgian Act	Art. 21(2)(e)	Network security
ISO/IEC 27001:2022	Annex A 8.22	Segregation of networks
NIST SP 800-53 Rev. 5	SC-7 / SC-32	Boundary protection and system partitioning
CIS Controls v8.1	Safeguard 12.2 (IG2)	Secure network architecture
CIS Cisco IOS Benchmark	§2.3.1	Native VLAN on unused VLAN
CIS Cisco IOS Benchmark	§2.3.2	Allow only required VLANs on trunks

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
T1557	Adversary-in-the-Middle	VLAN hopping via double-tagging allows an attacker to inject traffic into segmented VLANs without the L3-SW's ACLs filtering it.
T1021	Remote Services	Bypass of inter-VLAN boundaries grants lateral reachability to otherwise segmented services (management, servers).

SEVERITY RATIONALE

High: documented exploitability (Yersinia, scapy), surface = any internal network user, impact = bypass of main security measure.

REMEDIATION

Quick wins (< 1 week)

1. On SW2 Gi0/1: switchport trunk allowed vlan 10,20,30,40,50,60,70,80,99, switchport trunk native vlan 999, switchport nonegotiate.
2. Create unused VLAN 999 as native on all trunks.

Short term (1-3 months)

1. Automated trunk config audit (Ansible, Nornir, CIS Config Assessor).
2. Organizational configuration baseline enforcing these controls.

F-12 - Printers not assigned to a dedicated VLAN - systemic flaw across SW1, SW2, SW3

HIGH

EVIDENCE

Empirical verification across the 3 switches:

```
SW1#show running-config | section interface FastEthernet0/23
interface FastEthernet0/23
  spanning-tree portfast
  spanning-tree bpduguard enable

(identical on SW2 and SW3)
```

No switchport access vlan command on the 3 Fa0/23 ports → printers land in default VLAN 1.

OBSERVATION

The 3 printers (SW1/SW2/SW3_PRINTER) sit in native VLAN 1, not purged from trunks (see F-13).

SYSTEMIC flaw across 3 devices - indicates a gap in the organizational baseline.

RISK

Printers are a documented attack vector (vulnerable firmware, default credentials):

- Printer compromise → pivot in VLAN 1 → theoretical access to all VLANs via trunks.
- VLAN 1 historically the most attacked.
- No inventory of these assets (ID.AM-01).

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	PR.IR-01.2	Segmentation
CyFun 2025 Important	ID.AM-01.1	Physical asset inventory
NIS2 Belgian Act	Art. 21(2)(e)	Network security
ISO/IEC 27001:2022	Annex A 5.9	Inventory of information and other associated assets
ISO/IEC 27001:2022	Annex A 8.22	Segregation of networks
NIST SP 800-53 Rev. 5	SC-7 / CM-8	Boundary protection and system component inventory
CIS Controls v8.1	Safeguard 1.1 (IG1)	Inventory of enterprise assets
CIS Controls v8.1	Safeguard 12.2 (IG2)	Network segmentation

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
T1210	Exploitation of Remote Services	Printer firmware routinely contains unpatched CVEs exploitable from the same broadcast domain.
T1021	Remote Services	A foothold on a VLAN 1 printer gives reach into every VLAN whose trunk still permits VLAN 1.

SEVERITY RATIONALE

High: systemic problem on 3 devices. Would be Medium if localized.

REMEDIATION

Quick wins (< 1 week)

1. Create VLAN 80 PRINTERS on all switches.
2. Configure Fa0/23 (SW1/SW2/SW3): switchport mode access, switchport access vlan 80, switchport nonegotiate.
3. SVI VLAN 80 on L3-SW with restrictive ACL (ports 9100/IPP only from user VLANs).
4. Add VLAN 80 to allowed on all trunks, remove VLAN 1.

Short term (1-3 months)

1. Inventory printers in CMDB / asset register.
2. Change printer admin credentials.
3. Disable unnecessary services (FTP, Telnet, SNMPv1/v2c).

F-13 - Native VLAN 1 not purged across trunks

MEDIUM

EVIDENCE

Empirical verification on SW1 and SW3 (show interfaces trunk):

Port Native vlan Gig0/1 1 Gig0/2 1 Vlans allowed on trunk Gig0/1 1,10,20,30,40,50,60,70,99 Gig0/2 1,10,20,30,40,50,60,70,99

Native VLAN = 1 (default), VLAN 1 explicitly in allowed list.

OBSERVATION

Native VLAN 1 not purged on any trunk. Systemic flaw across all switches.

RISK

802.1Q double-tagging attack: outer tag = native VLAN 1 stripped by switch, inner tag forwarded to target VLAN.

Residual risk (less severe than a fully permissive trunk - F-11).

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	PR.IR-01.2	Segmentation
ISO/IEC 27001:2022	Annex A 8.22	Segregation of networks
NIST SP 800-53 Rev. 5	SC-7	Boundary protection
CIS Cisco IOS Benchmark	§2.3.1	Native VLAN to unused VLAN ID
CIS Controls v8.1	Safeguard 12.2 (IG2)	Secure network architecture

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
T1557	Adversary-in-the-Middle	Double-tagging exploits native VLAN handling to inject unidirectional traffic across segmentation boundaries.

SEVERITY RATIONALE

Medium: residual risk, exploitation requires specific conditions.

REMEDIATION

Quick wins (< 1 week)

1. Create VLAN 999 (UNUSED-NATIVE) on all switches.
2. On ALL trunks: switchport trunk native vlan 999.
3. Remove VLAN 1 from allowed: switchport trunk allowed vlan 10,20,30,40,50,60,70,80,99.

F-14 - AAA protocol mismatch - TACACS+ clients vs RADIUS server

HIGH

EVIDENCE

AAA server screenshot (Services → AAA):

Client config §13.10.3:

```
tacacs-server host 192.168.10.130
tacacs-server key cisco@123!
aaa authentication login TAC_auth group tacacs+ local
```

OBSERVATION

Switches query in TACACS+ on port 49, server responds in RADIUS on port 1645. Incompatible protocols.

Centralized authentication is technically inoperative. Only local fallback works (empirically confirmed: L3-SW login with local user-a account).

RISK

The organization believes it has centralized AAA when in reality:

- Each switch falls back to an isolated local database.
- No functional TACACS+ accounting.
- No centralized revocation.
- Any rights change requires touching all 5 devices individually.

PR.AA-05.5 (centralized AAA) is factually invalidated - the initial score must be reassessed.

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	PR.AA-05.5	Centralized access and monitoring
CyFun 2025 Important	PR.AA-01.2	Credentials managed securely
NIS2 Belgian Act	Art. 21(2)(i)	Access management
ISO/IEC 27001:2022	Annex A 8.2	Privileged access rights
ISO/IEC 27001:2022	Annex A 8.5	Secure authentication
NIST SP 800-53 Rev. 5	IA-2 / IA-8 / AC-2	Identification and authentication, account management
SOC 2	CC6.1	Logical access controls
CIS Controls v8.1	Safeguard 6.2 (IG1)	Establish an access granting process
CIS Controls v8.1	Safeguard 6.7 (IG2)	Centralize access control

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
T1078.001	Valid Accounts: Default Accounts	Silent fallback to local accounts bypasses centralized control and accounting, letting default/weak local credentials persist unnoticed.

SEVERITY RATIONALE

High: technical inconsistency invalidating a claimed measure. Not Critical because local fallback preserves continuity.

REMEDIATION

Quick wins (< 1 week)

1. Decision: TACACS+ OR RADIUS, then align both sides.
2. If TACACS+: replace server with tac_plus (Linux) or Cisco ISE.
3. If RADIUS: reconfigure switches (radius-server host, aaa authentication login default group radius local).

Short term (1-3 months)

1. Lab test before production migration.

2. Rollback plan.
3. Document final configuration in a runbook.

F-15 - AAA user base with trivial credentials (username = password)

CRITICAL

EVIDENCE

AAA server screenshot - User Setup section:

Username Password user-a user-a user-b user-b user-c user-c

Empirical verification: successful L3-SW login with user-a/user-a (local fallback took over - see F-14).

OBSERVATION

Three accounts where username = password. A pattern typical of lab configurations that never belong in production.

Credentials visible in cleartext in AAA server config.

RISK

- Username enumeration + first-name dictionary → guaranteed access.
- Accounts tied to identifiable individuals - risk of persistence for former interns.
- Combined with F-03 (shared enable), each trivial account = full admin.

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	PR.AA-01.2 (score 1)	Credentials managed
CyFun 2025 Important	PR.AA-03.1	Password policy
NIS2 Belgian Act	Art. 21(2)(i)	Access control
GDPR	Art. 32(1)(b)	System confidentiality
APD / GBA	2023 Guidelines	Authenticator robustness
ISO/IEC 27001:2022	Annex A 5.17	Authentication information
ISO/IEC 27001:2022	Annex A 8.5	Secure authentication
NIST SP 800-53 Rev. 5	IA-5 / IA-5(1)	Authenticator management - password-based
SOC 2	CC6.1	Logical access
CIS Controls v8.1	Safeguard 5.2 (IG1)	Use unique passwords
CIS Controls v8.1	Safeguard 5.3 (IG1)	Disable dormant accounts
ANSSI	Password recommendations	Minimum entropy required

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
T1110.001	Brute Force: Password Guessing	First-name dictionary reproduces the exact password set; exploitation takes seconds.
T1078	Valid Accounts	Guessed credentials authenticate legitimately, leaving no anomalous signal in authentication logs.

SEVERITY RATIONALE

Critical: credentials exploitable in seconds. Direct empirical evidence (AAA server screenshot).

REMEDIATION

Immediate action (< 24h)

1. Audit the 3 accounts: identify real owners.
2. Delete orphaned accounts (former users).
3. Force password reset (≥ 14 characters, high complexity).

Short term (1-3 months)

1. Enforced password policy on AAA server.
2. Formalized onboarding / offboarding process.

F-16 - Undocumented perimeter filtering and FTP in cleartext

HIGH

EVIDENCE

§7.7: FTP over plain protocol (port 21) with no FTPS/SFTP.

§7.7.2: FTP credentials visible in the deliverable (user-b/123456, cisco/cisco).

No documented firewall rules (confirmed by F-10: ASA in factory configuration).

OBSERVATION

FTP server routed directly by R1 without DMZ. ASA unconfigured → no real perimeter filtering.

Credentials in the deliverable - a documentary incident on its own.

RISK

- FTP credentials capturable in cleartext (Wireshark).
- Files transferred in cleartext (potentially personal data - GDPR Art. 32(1)(a) non-compliance).

Credentials user-b/123456 appear in all common brute-force dictionaries.

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	PR.DS-01.1	Encryption in transit
CyFun 2025 Important	PR.IR-01.1	Firewalls configured
NIS2 Belgian Act	Art. 21(2)(h)	Cryptography
GDPR	Art. 32(1)(a)	Data encryption
APD / GBA	SME security guide	Encrypted protocols for data transfer
ISO/IEC 27001:2022	Annex A 8.20	Networks security
ISO/IEC 27001:2022	Annex A 8.24	Use of cryptography
NIST SP 800-53 Rev. 5	SC-8 / IA-5	Transmission confidentiality and authenticator management
SOC 2	CC6.7	Transmission of data
CIS Controls v8.1	Safeguard 3.10 (IG2)	Encrypt sensitive data in transit
CIS Controls v8.1	Safeguard 4.8 (IG2)	Disable unnecessary services

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
T1040	Network Sniffing	FTP credentials and file contents travel in cleartext and are visible to any attacker with L2 access.
T1552.001	Unsecured Credentials: Credentials In Files	Credentials embedded in the deliverable itself enable access with no network foothold required.

SEVERITY RATIONALE

High: FTP in cleartext immediately exploitable. Firewall ruleset non-existent (evidence F-10).

REMEDIATION

Quick wins (< 1 week)

1. Replace FTP with SFTP (SSH) or FTPS (FTP/TLS).
2. Change documented credentials and remove from the deliverable.
3. Document firewall ruleset (pending ASA configuration - see F-10).

Short term (1-3 months)

1. Firewall ruleset hardening (default-deny).
2. Egress filtering to limit C2.
3. Quarterly firewall rules review.

F-17 - Inter-VLAN ACLs defined but not applied on L3-SW SVIs

CRITICAL

EVIDENCE

Document §13.6.1 EXPLICITLY documents ACL application:

13.6.1 Applying ACL rules on the vlan interfaces:

```
interface Vlan 10
  ip access-group ACL_V10_MGMT in
interface Vlan 20
  ip access-group ACL_V20_STUDY in
(...) same for VLAN 30, 40, 50, 60, 99
```

Empirical verification on L3-SW reveals these commands are NOT present in running-config:

```
L3-SW#show running-config | section interface Vlan10
interface Vlan10
  mac-address 0001.96d6.b401
  ip address 192.168.10.33 255.255.255.240
  ip helper-address 192.168.10.115
                                     ← NO ip access-group

L3-SW#show running-config | section interface Vlan20
interface Vlan20
  mac-address 0001.96d6.b402
  ip address 192.168.10.1 255.255.255.224
  ip helper-address 192.168.10.115
                                     ← NO ip access-group
```

show access-lists confirms: ACLs are defined (ACL_V10_MGMT, ACL_V20_STUDY, etc. visible) but with no hit counters (indicator of a non-applied inbound ACL).

OBSERVATION

The 7 inter-VLAN ACLs (ACL_V10_MGMT, ACL_V20_STUDY, ACL_V30_PROD, ACL_V40_SUPPA, ACL_V50_SUPPB, ACL_V60_IT, ACL_V99_MGMT) are cleanly defined in running-config with coherent, detailed rules. But NONE is applied on the SVIs via ip access-group.

MAJOR gap between documentation (§13.6.1 describes application) and technical reality (application commands missing).

L2 segmentation via VLANs remains effective, but the inter-VLAN filtering policy meant to compensate for open routing (inter-VLAN routing enabled on L3-SW) IS NOT APPLIED.

RISK

Direct and immediate impact:

- Inter-VLAN routing operates WITHOUT any filtering: any VLAN can reach any other via the L3-SW.
- A PC in VLAN 20 (Study - low-trust users) can freely reach VLAN 70 (Servers), VLAN 10 (Management), VLAN 60 (IT).
- The claims in §9 ("Access Control Lists can be applied to control inter-VLAN communication") and §10.1 (ISO 27001 "VLAN segmentation restricts cross-department access") are factually false in the current state.
- None of the carefully constructed deny ip any <subnet> rules have any effect.

This finding invalidates the design's main claimed security measure. It is consistent with the systemic "documentary claim ≠ implementation" pattern also observed in F-10 (ASA), F-14 (AAA) and F-18 (VTY).

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	PR.IR-01.2 (score to reassess to 1)	Effective network segmentation
CyFun 2025 Important	PR.IR-01.4	Boundary protection measures
CyFun 2025 Important	PR.PS-01.1	Configuration baseline
NIS2 Belgian Act	Art. 21(2)(e)	Network security
GDPR	Art. 32(1)(b)	Confidentiality, integrity (functional separation missing)
ISO/IEC 27001:2022	Annex A 8.20	Networks security
ISO/IEC 27001:2022	Annex A 8.22	Segregation of networks
ISO/IEC 27001:2022	Annex A 5.14	Information transfer
ISO/IEC 27005:2022	§8.3	Risk analysis - control effectiveness
NIST SP 800-53 Rev. 5	AC-3 / AC-4 / SC-7	Access enforcement, information flow, boundary protection
SOC 2	CC6.6	Boundary protection
CIS Controls v8.1	Safeguard 12.2 (IG2)	Establish and maintain a secure network architecture
CIS Controls v8.1	Safeguard 3.3 (IG1)	Configure data access control lists

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
T1021	Remote Services	Open inter-VLAN routing lets any user VLAN reach administrative and server VLANs over SSH/RDP/SMB/etc. as if flat.
T1570	Lateral Tool Transfer	Absence of enforced ACLs enables free lateral transfer of tooling across segments the design claimed to isolate.

SEVERITY RATIONALE

Maximum severity: empirically invalidates the main security measure claimed by the design. Documentation/ reality gap proven via CLI. Immediate exploitability for any internal user.

REMEDIATION

Emergency action (< 24h)

1. Apply the 7 ACLs to the corresponding SVIs on L3-SW:

Commands to execute immediately

1. interface Vlan10 / ip access-group ACL_V10_MGMT in
2. interface Vlan20 / ip access-group ACL_V20_STUDY in
3. interface Vlan30 / ip access-group ACL_V30_PROD in
4. interface Vlan40 / ip access-group ACL_V40_SUPPA in
5. interface Vlan50 / ip access-group ACL_V50_SUPPB in
6. interface Vlan60 / ip access-group ACL_V60_IT in
7. interface Vlan99 / ip access-group ACL_V99_MGMT in
8. write memory to save configuration.

Quick wins (< 1 week)

1. Verify application: show ip access-lists (hit counters should now appear).
2. Test from each VLAN that deny/permit rules apply correctly.
3. Document the verification procedure for future deployments.

Short term (1-3 months)

1. Automate post-deployment validation: script comparing running-config to documented requirements.
2. Add "documentation vs reality" check to change management.
3. Full review of other §10.1 claims to detect similar gaps.

F-18 - VTY lines 5-15 not hardened on SW1, SW2, SW3 - Telnet access possible by default

HIGH**EVIDENCE**

Empirical verification across the 3 access switches:

```
SW1#show running-config | section line vty
line vty 0 4
  exec-timeout 3 0
  login authentication TAC_auth
  transport input ssh
line vty 5 15
                                     ← EMPTY BLOCK
```

(identical results on SW2 and SW3)

The line vty 5 15 block is declared on the 3 switches but contains no directive (no transport input ssh, no login authentication, no exec-timeout).

Consistent with §13.1 (Common Commands) of the PDF which declares vty 5-15 with only login (default behavior = Telnet accepted).

OBSERVATION

On Cisco IOS 2960, a VTY line declared without transport input accepts Telnet (cleartext) by default alongside or instead of SSH.

Direct impact: VTYS 5 to 15 potentially accept unencrypted Telnet sessions on SW1, SW2, SW3. 11 VTY sessions per switch are vulnerable.

L3-SW is NOT affected (line vty 5 15 not declared - empirically verified).

RISK

- An attacker who found credentials (via F-15 or dictionary) can attempt a Telnet connection on VTYS 5-15 of access switches.
- Telnet is in cleartext: packet capture with Wireshark reveals username and password instantly.
- The Telnet channel is commonly overlooked in surface audits - a classic pentest finding.
- Inconsistent with design intent (SSH v2 claimed everywhere §13.10.1).

REGULATORY AND NORMATIVE MAPPING

Framework	Reference	Requirement
CyFun 2025 Important	PR.AA-03.2	Secure authentication
CyFun 2025 Important	PR.DS-01.1	Confidentiality in transit
CyFun 2025 Important	PR.PS-01.1	Configuration baseline
NIS2 Belgian Act	Art. 21(2)(h)	Cryptography
GDPR	Art. 32(1)(a)	Encryption of admin communications
ISO/IEC 27001:2022	Annex A 8.24	Use of cryptography
NIST SP 800-53 Rev. 5	AC-17 / SC-8	Remote access and transmission confidentiality
SOC 2	CC6.7	Transmission of data - encryption
CIS Cisco IOS Benchmark	§1.2.6	Set transport input ssh on all VTY lines
CIS Cisco IOS Benchmark	§1.2.3	Set exec-timeout on VTY
CIS Controls v8.1	Safeguard 4.8 (IG2)	Disable unnecessary services
CIS Controls v8.1	Safeguard 3.10 (IG2)	Encrypt sensitive data in transit

MITRE ATT&CK MAPPING

Technique ID	Technique	Application to this finding
T1021	Remote Services	Unrestricted VTY lines accept Telnet, offering an alternate remote admin channel outside the design's intended SSH baseline.
T1040	Network Sniffing	Cleartext Telnet on VTY 5-15 exposes admin credentials to any attacker able to capture traffic on the management path.

SEVERITY RATIONALE

High: technically simple to exploit, systemically present across the 3 access switches. Direct empirical evidence via show running-config.

REMEDIATION

Quick wins (< 1 week)

1. On SW1, SW2 and SW3, apply full VTY 5-15 hardening:
2. line vty 5 15
3. exec-timeout 3 0
4. login authentication TAC_auth
5. transport input ssh
6. write memory on each device.
7. Verify with show running-config | section line vty that the config is consistent with vty 0 4.

Short term (1-3 months)

1. Integrate this check into the organizational configuration baseline.
2. Compliance script: automatic grep for transport input ssh on all VTY lines of all devices.

5. Risk Summary Table

Consolidation of the 18 findings.

ID	Finding	Severity	Priority
F-01	Shared administrator secret across the entire scope	Critical	0-30d
F-02	No multi-factor authentication on privileged access	Critical	0-30d
F-03	No privilege segregation - single-level authentication model	High	0-30d
F-04	No centralization or correlation of security logs	Critical	0-30d
F-05	No detection capability (anti-malware, IDS/IPS, EDR)	High	0-30d
F-06	No backup or recovery mechanism	Critical	0-30d
F-07	No incident response plan	High	0-30d
F-08	No vulnerability management or patch management	High	0-30d
F-09	Undersized SSH cryptography (RSA 1024-bit keys)	High	0-30d
F-10	ASA 5506-X firewall in factory configuration - no authentication, no filtering	Critical	0-30d
F-11	Permissive trunk configuration on SW2 - no VLAN restriction	High	0-30d
F-12	Printers not assigned to a dedicated VLAN - systemic flaw across SW1, SW2, SW3	High	0-30d
F-13	Native VLAN 1 not purged across trunks	Medium	0-30d
F-14	AAA protocol mismatch - TACACS+ clients vs RADIUS server	High	0-30d
F-15	AAA user base with trivial credentials (username = password)	Critical	0-30d
F-16	Undocumented perimeter filtering and FTP in cleartext	High	0-30d
F-17	Inter-VLAN ACLs defined but not applied on L3-SW SVIs	Critical	0-30d
F-18	VTY lines 5-15 not hardened on SW1, SW2, SW3 - Telnet access possible by default	High	0-30d

Distribution:

- **Critical (5):** F-01, F-02, F-04, F-06, F-10, F-15, F-17
- **High (10):** F-03, F-05, F-07, F-08, F-09, F-11, F-12, F-14, F-16, F-18
- **Medium (1):** F-13

6. Remediation Roadmap

Aggregated actions derived from the 18 findings, organized by time horizon.

6.1 Quick wins and immediate actions (< 1 week)

- [F-01] Generate a unique password per device (≥ 14 characters), stored in a secret vault.
- [F-01] Replace Type 5 with Type 9 (scrypt): enable algorithm-type scrypt secret <password>.
- [F-01] Rename the admin account (e.g. netadm-sw1) to prevent enumeration.
- [F-01] Generate a distinct TACACS+ key, unique per device/AAA server pair.
- [F-02] Restrict source IPs allowed to initiate SSH (harden management VLAN 99 ACL).
- [F-03] Create individual named accounts for each admin.
- [F-03] Remove or restrict use of the generic admin account.
- [F-03] Enable TACACS+ accounting (after F-14 remediation) on all devices.
- [F-04] Configure NTP on all devices (ntp server or internal server).
- [F-04] Enable local logging with maximum retention and ISO 8601 timestamps (service timestamps log datetime msec show-timezone).
- [F-05] Enable native IOS features: IP Source Guard, DHCP Snooping, Dynamic ARP Inspection.
- [F-06] Manually export (copy running-config tftp:) configs of the 5 devices. IMMEDIATELY.
- [F-06] Document the manual recovery procedure.
- [F-06] Set up a versioned Git repository for backed-up configurations.
- [F-07] Named IR responsible (primary + backup).
- [F-07] Paper emergency booklet: CERT.be (+32 2 790 33 33), CCB, APD, internal contacts.
- [F-07] Register with the CERT.be portal.
- [F-08] Subscribe to Cisco PSIRT, CCB, CERT.be feeds.
- [F-08] Inventory of firmware versions vs stable releases.
- [F-09] Regenerate RSA keys 2048+ (3072 recommended): crypto key zeroize rsa then crypto key generate rsa modulus 2048.
- [F-09] Restrict SSH algorithms: minimum aes256-ctr, hmac-sha2-512, diffie-hellman-group14-sha256.
- [F-09] Verify SSHv2 only.
- [F-10] Set a strong enable secret: enable algorithm-type scrypt secret <password>.
- [F-10] Keep Gi1/2 shutdown pending full configuration.
- [F-10] Minimum config: nameif inside (security-level 100) on Gi1/1, nameif outside (security-level 0) on Gi1/2, dynamic NAT.
- [F-10] OUTSIDE_IN ACL with default-deny + explicit exceptions.
- [F-10] Default route to ISP.
- [F-10] Document ASA credentials in the secret vault.
- [F-11] On SW2 Gi0/1: switchport trunk allowed vlan 10,20,30,40,50,60,70,80,99, switchport trunk native vlan 999, switchport nonegotiate.
- [F-11] Create unused VLAN 999 as native on all trunks.
- [F-12] Create VLAN 80 PRINTERS on all switches.
- [F-12] Configure Fa0/23 (SW1/SW2/SW3): switchport mode access, switchport access vlan 80, switchport nonegotiate.
- [F-12] SVI VLAN 80 on L3-SW with restrictive ACL (ports 9100/IPP only from user VLANs).
- [F-12] Add VLAN 80 to allowed on all trunks, remove VLAN 1.
- [F-13] Create VLAN 999 (UNUSED-NATIVE) on all switches.
- [F-13] On ALL trunks: switchport trunk native vlan 999.
- [F-13] Remove VLAN 1 from allowed: switchport trunk allowed vlan 10,20,30,40,50,60,70,80,99.

- [F-14] Decision: TACACS+ OR RADIUS, then align both sides.
- [F-14] If TACACS+: replace server with tac_plus (Linux) or Cisco ISE.
- [F-14] If RADIUS: reconfigure switches (radius-server host, aaa authentication login default group radius local).
- [F-15] Audit the 3 accounts: identify real owners.
- [F-15] Delete orphaned accounts (former users).
- [F-15] Force password reset (≥ 14 characters, high complexity).
- [F-16] Replace FTP with SFTP (SSH) or FTPS (FTP/TLS).
- [F-16] Change documented credentials and remove from the deliverable.
- [F-16] Document firewall ruleset (pending ASA configuration - see F-10).
- [F-17] Apply the 7 ACLs to the corresponding SVIs on L3-SW:
- [F-17] interface Vlan10 / ip access-group ACL_V10_MGMT in
- [F-17] interface Vlan20 / ip access-group ACL_V20_STUDY in
- [F-17] interface Vlan30 / ip access-group ACL_V30_PROD in
- [F-17] interface Vlan40 / ip access-group ACL_V40_SUPPA in
- [F-17] interface Vlan50 / ip access-group ACL_V50_SUPPB in
- [F-17] interface Vlan60 / ip access-group ACL_V60_IT in
- [F-17] interface Vlan99 / ip access-group ACL_V99_MGMT in
- [F-17] write memory to save configuration.
- [F-17] Verify application: show ip access-lists (hit counters should now appear).
- [F-17] Test from each VLAN that deny/permit rules apply correctly.
- [F-17] Document the verification procedure for future deployments.
- [F-18] On SW1, SW2 and SW3, apply full VTY 5-15 hardening:
- [F-18] line vty 5 15
- [F-18] exec-timeout 3 0
- [F-18] login authentication TAC_auth
- [F-18] transport input ssh
- [F-18] write memory on each device.
- [F-18] Verify with show running-config | section line vty that the config is consistent with vty 0 4.

6.2 Short term (1 to 3 months)

- [F-01] Deploy a secret vault (HashiCorp Vault, CyberArk).
- [F-01] Define a password policy (length, quarterly rotation, complexity).
- [F-01] Enable full authentication audit on the AAA server.
- [F-02] MFA-capable RADIUS server (FreeRADIUS + Duo, Cisco ISE).
- [F-02] Delegate authentication to MFA with local fallback only during network outage.
- [F-02] Train admins on MFA enforcement.
- [F-03] Differentiated Cisco IOS privilege levels (0-15) to separate read/config access.
- [F-03] Documented RACI matrix.
- [F-03] Quarterly review of privileged access.
- [F-04] Centralized syslog server (rsyslog, Graylog) in Servers VLAN.
- [F-04] logging host on all devices, informational level.
- [F-04] Retention policy (minimum 6 months, 12 months recommended for NIS2).
- [F-04] Redundant internal stratum-2 NTP server.
- [F-05] EDR on endpoints (Defender, CrowdStrike, SentinelOne).
- [F-05] Network IDS sensor (Suricata, Snort, Zeek) on SPAN port of L3-SW.
- [F-05] Netflow on R1.
- [F-06] Backup server (Veeam, Bacula) in Servers VLAN.

- [F-06] Daily automated backup via TFTP/SCP.
- [F-06] Encrypted FTP and AAA backups (3-2-1 rule).
- [F-06] Documented quarterly restore test.
- [F-07] Structured IR plan per NIST SP 800-61r2 (Preparation/Detection/Containment/Eradication/Recovery/Lessons).
- [F-07] Incident classification matrix (Low → Critical).
- [F-07] Formalized external notification process (CCB, CERT.be, APD).
- [F-08] Patch management process (monthly cycle + 7-day emergency for critical CVEs).
- [F-08] Vulnerability scanner (OpenVAS, Nessus, Qualys) - monthly scan.
- [F-08] Tracking table with CVSS severity-based SLA.
- [F-09] Organizational cryptographic policy aligned with ANSSI/BSI.
- [F-09] Annual key rotation, mandatory at each admin departure.
- [F-10] Per-service filtering rules, application inspection, syslog logging, SNMPv3.
- [F-10] DMZ creation for FTP.
- [F-11] Automated trunk config audit (Ansible, Nornir, CIS Config Assessor).
- [F-11] Organizational configuration baseline enforcing these controls.
- [F-12] Inventory printers in CMDB / asset register.
- [F-12] Change printer admin credentials.
- [F-12] Disable unnecessary services (FTP, Telnet, SNMPv1/v2c).
- [F-14] Lab test before production migration.
- [F-14] Rollback plan.
- [F-14] Document final configuration in a runbook.
- [F-15] Enforced password policy on AAA server.
- [F-15] Formalized onboarding / offboarding process.
- [F-16] Firewall ruleset hardening (default-deny).
- [F-16] Egress filtering to limit C2.
- [F-16] Quarterly firewall rules review.
- [F-17] Automate post-deployment validation: script comparing running-config to documented requirements.
- [F-17] Add "documentation vs reality" check to change management.
- [F-17] Full review of other §10.1 claims to detect similar gaps.
- [F-18] Integrate this check into the organizational configuration baseline.
- [F-18] Compliance script: automatic grep for transport input ssh on all VTY lines of all devices.

6.3 Long term (6 to 18 months)

- [F-01] MFA on all administrative access.
- [F-01] Automated secret rotation via vault.
- [F-02] Administrative bastion with MFA and session recording.
- [F-02] Integration with organizational IdP.
- [F-03] PAM solution (CyberArk, BeyondTrust).
- [F-03] Video recording of critical sessions.
- [F-04] SIEM (Splunk, Elastic, Wazuh, Sentinel).
- [F-04] Monitoring runbook (thresholds, escalation, SLA).
- [F-04] Integration with internal or outsourced SOC.
- [F-05] Integrate IDS/EDR alerts into SIEM.
- [F-05] Proactive threat hunting.
- [F-06] Formal BCP/DRP with RTO/RPO.
- [F-06] Annual DRP test under real conditions.

- [F-06] Immutable offline backups (WORM, air-gap) against ransomware.
- [F-07] Annual cyber crisis tabletop exercise.
- [F-07] Team training in basic forensics.
- [F-07] External IR provider retainer.
- [F-08] Automated patch deployment (WSUS, Ansible, SCCM).
- [F-08] Public CVD program per ID.RA-08.
- [F-08] SBOM requirements on suppliers (CRA Art. 13 obligation).
- [F-09] Post-quantum migration (NIST PQC: Kyber, Dilithium) - roadmap by 2030.
- [F-10] Evaluate ASA 5506-X replacement (End-of-Sale August 2022 - CRA requires ongoing support).

7. Conclusion

7.1 Summary

The hybrid documentary + empirical + multi-framework audit revealed a significant and systemic gap between the deliverable's claims and the technical reality. Four findings (F-10, F-14, F-17, F-18) share the same root cause: absence of final documentation/implementation review.

On pure technical grounds, the design presents a sound architectural base (VLAN segmentation, 3-tier hierarchy, service positioning), but the claimed security measures (firewall, centralized AAA, ACLs, SSH-only) are partially or fully inoperative in the actual configuration. Combined with the total absence of DETECT, RESPOND and RECOVER capabilities, the organization is unable to meet its NIS2 obligations.

7.2 Current compliance vs CyFun Important target

- GOVERN: not assessable (out of scope).
- IDENTIFY: partially compliant - inventory present but vulnerability management absent.
- PROTECT: deficient - segmentation inoperative (F-17), firewall non-functional (F-10), trivial credentials (F-01, F-15), deprecated crypto (F-09).
- DETECT: non-compliant - complete absence (F-04, F-05).
- RESPOND: non-compliant - absence of IR plan (F-07).
- RECOVER: non-compliant - absence of backups (F-06).

7.3 Strategic recommendations

1. Execute the 3 immediate actions (< 24h) upon report validation (ACL application, ASA enable secret, config export).
2. Appoint a cybersecurity owner with a clear mandate.
3. Allocate a dedicated cybersecurity budget (€30-80k for short-term actions).
4. Multi-year cybersecurity program with quarterly review.
5. Verification audit at 6 months to measure progress.
6. IMMEDIATE AUDIT OF §10.1 of the deliverable: the systemic pattern requires a full review of ALL claims to detect gaps beyond F-10, F-14, F-17, F-18.

7.4 Closing remarks

This audit should be read as a snapshot of a design in progressive maturation. The 18 findings are not a definitive judgment on the designers' skills but an actionable basis to industrialize the security approach in a prioritized, measurable way.

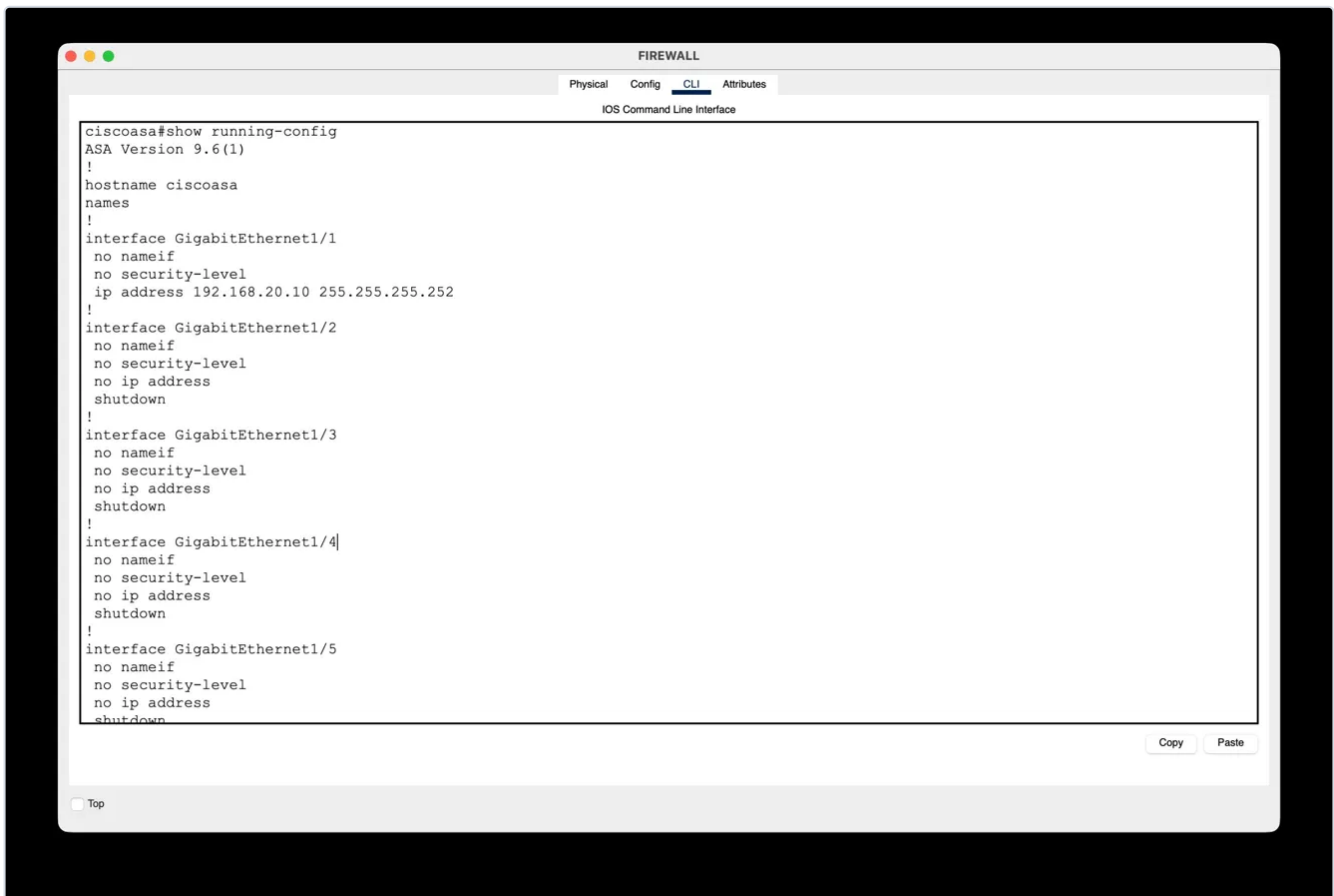
The audit team remains available for clarification, executive briefing, or support in defining the remediation program.

Annex A - Empirical evidence screenshots

This annex contains the screenshots captured during the live CLI verification of the Packet Tracer file. Each screenshot is reproducible on demand by running the same commands on the .pkt file provided with the project.

8 screenshots are embedded below and directly support findings F-01, F-02, F-04, F-10, F-11 (by comparison), F-12 and F-13. Four additional findings (F-11 on SW2 specifically, F-14, F-15, F-17, F-18) were also verified empirically via CLI during the audit session but their screenshots are not included in this iteration - the transcripts of those checks appear in the Evidence section of each corresponding finding in Chapter 4.

Screenshot 1 - ASA show running-config (beginning)



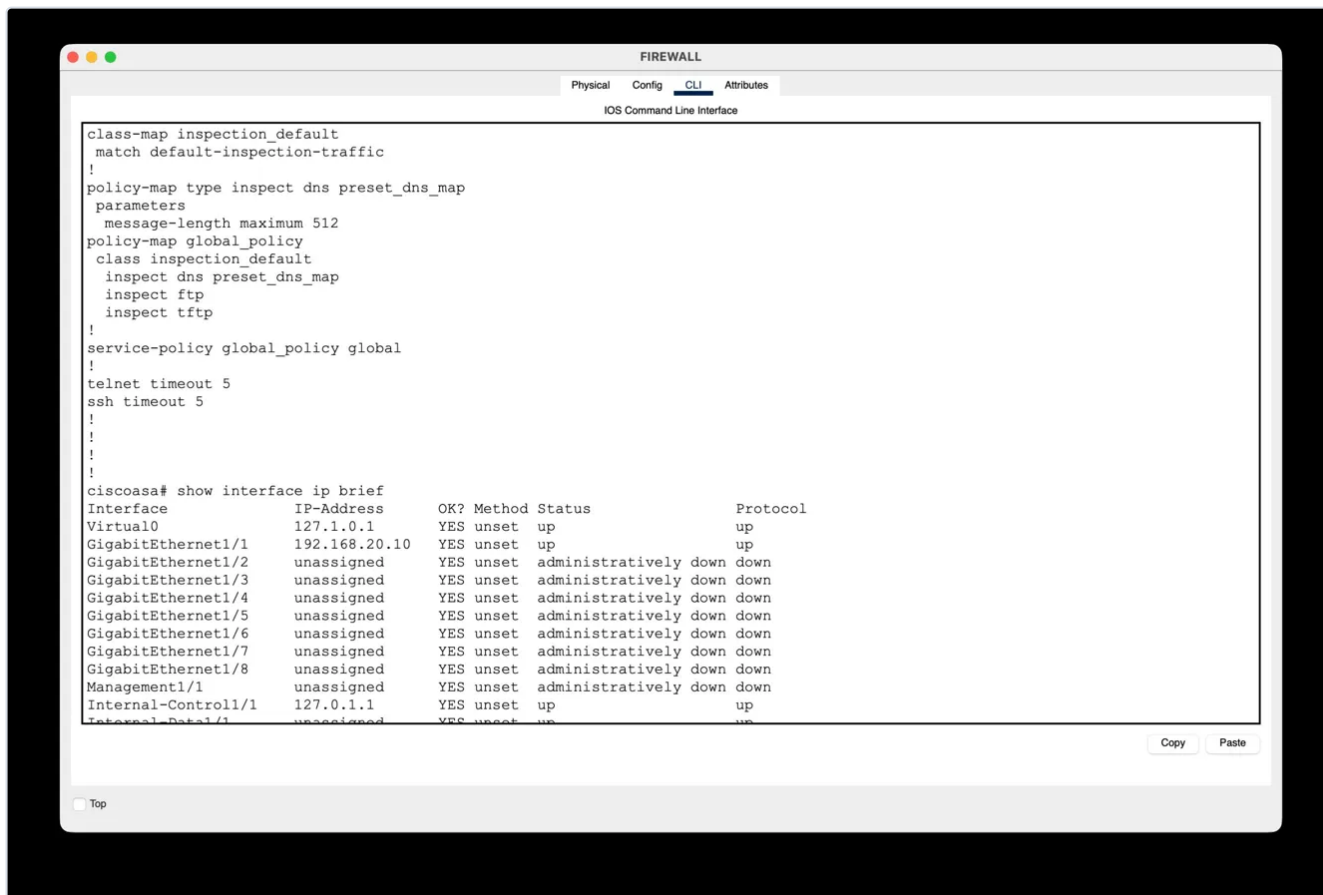
ASA CLI - hostname ciscoasa (default, not renamed); GigabitEthernet1/1 with IP 192.168.20.10 but no nameif and no security-level; Gi1/2 through Gi1/5 all declared no nameif, no security-level, shutdown. Supports finding F-10.

Screenshot 2 - ASA show running-config (continuation)



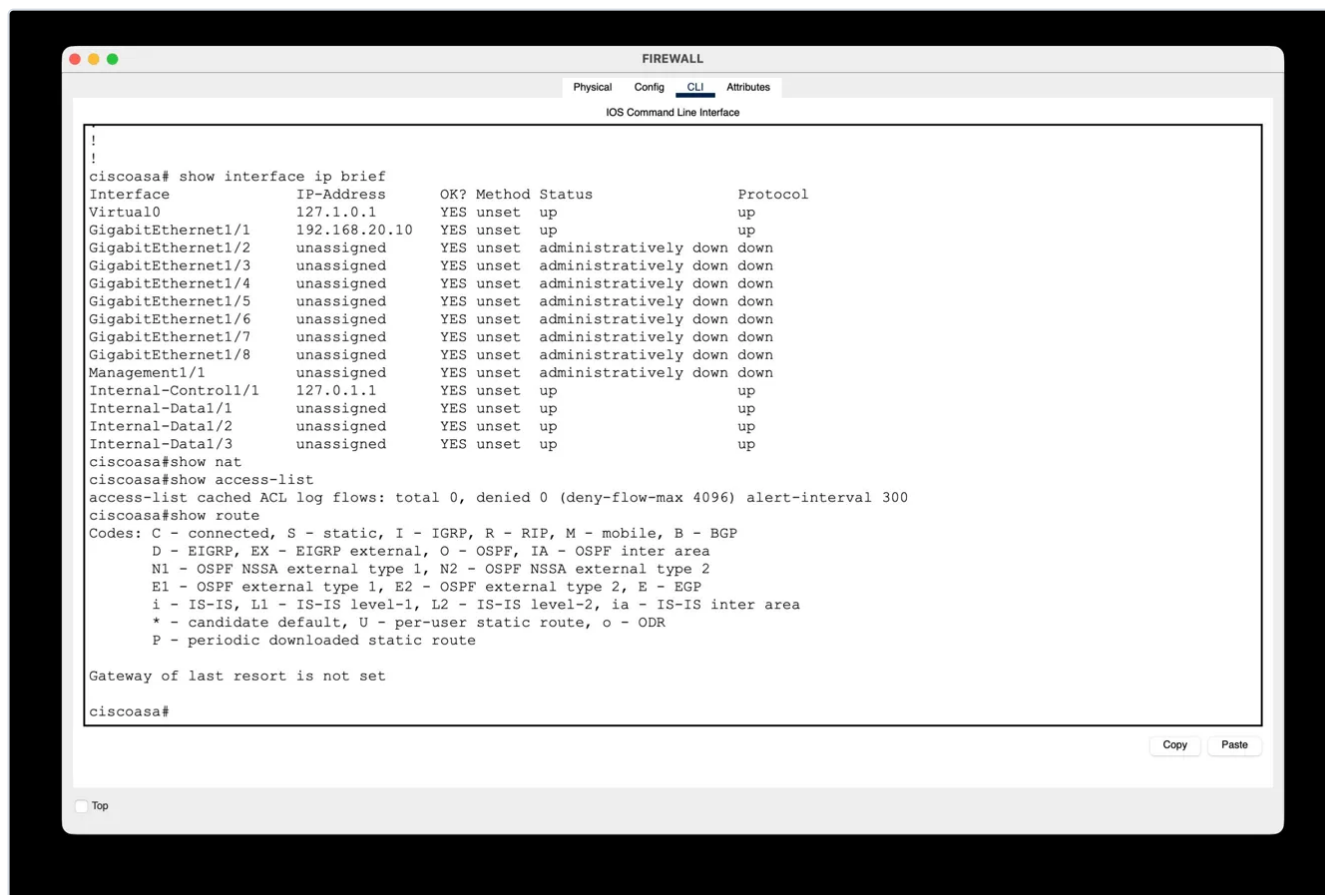
ASA CLI - GigabitEthernet1/7, 1/8 and Management1/1 all administratively down with no nameif. Only default class-map inspection_default and global_policy present (inspect dns, ftp, tftp presets). No custom security policy. Supports finding F-10.

Screenshot 3 - ASA show interface ip brief



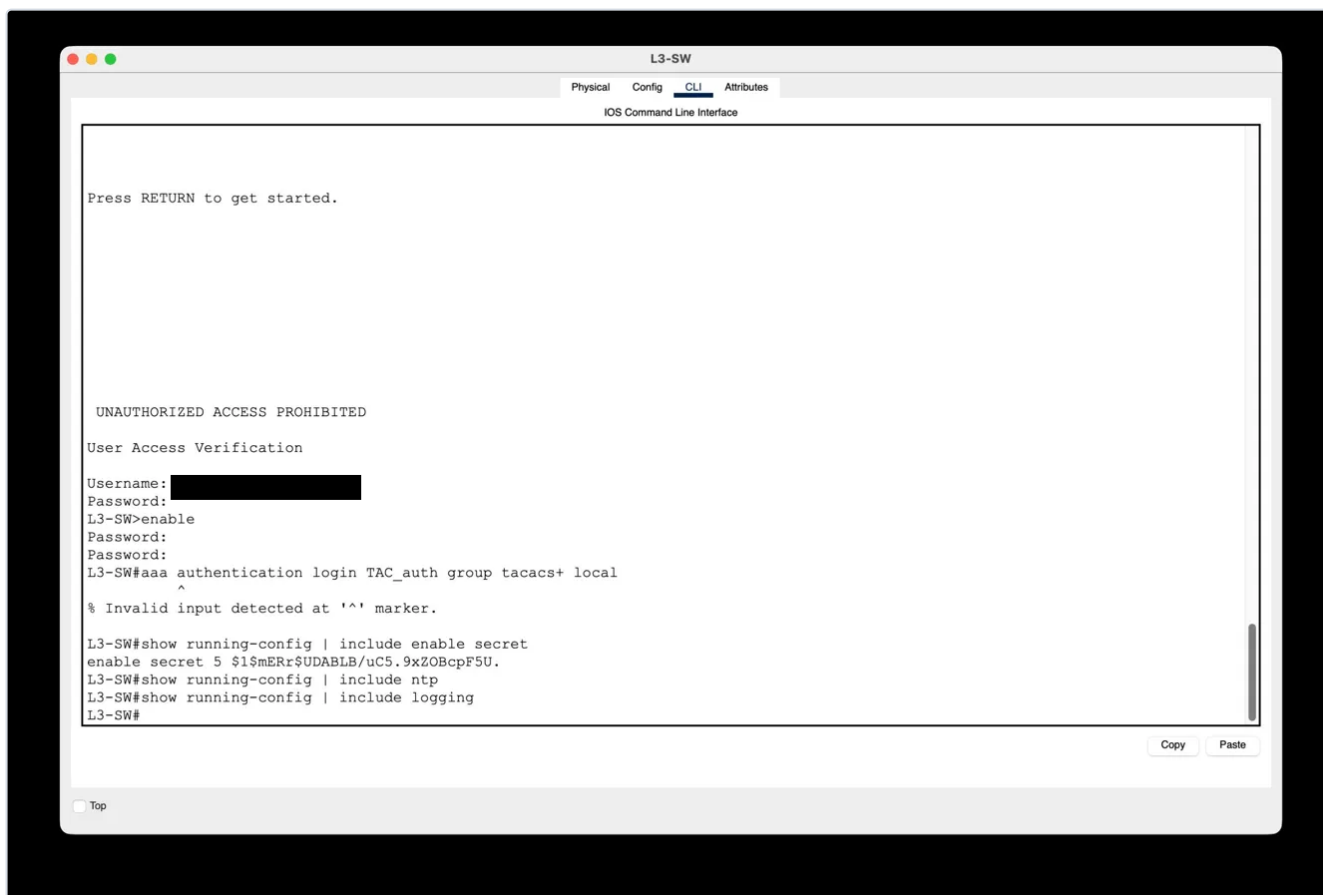
ASA CLI - show interface ip brief: 8 out of 9 data interfaces are administratively down. Only Gi1/1 is up with IP address. Internet-facing interface Gi1/2 is shutdown. Supports finding F-10.

Screenshot 4 - ASA show nat / show access-list / show route



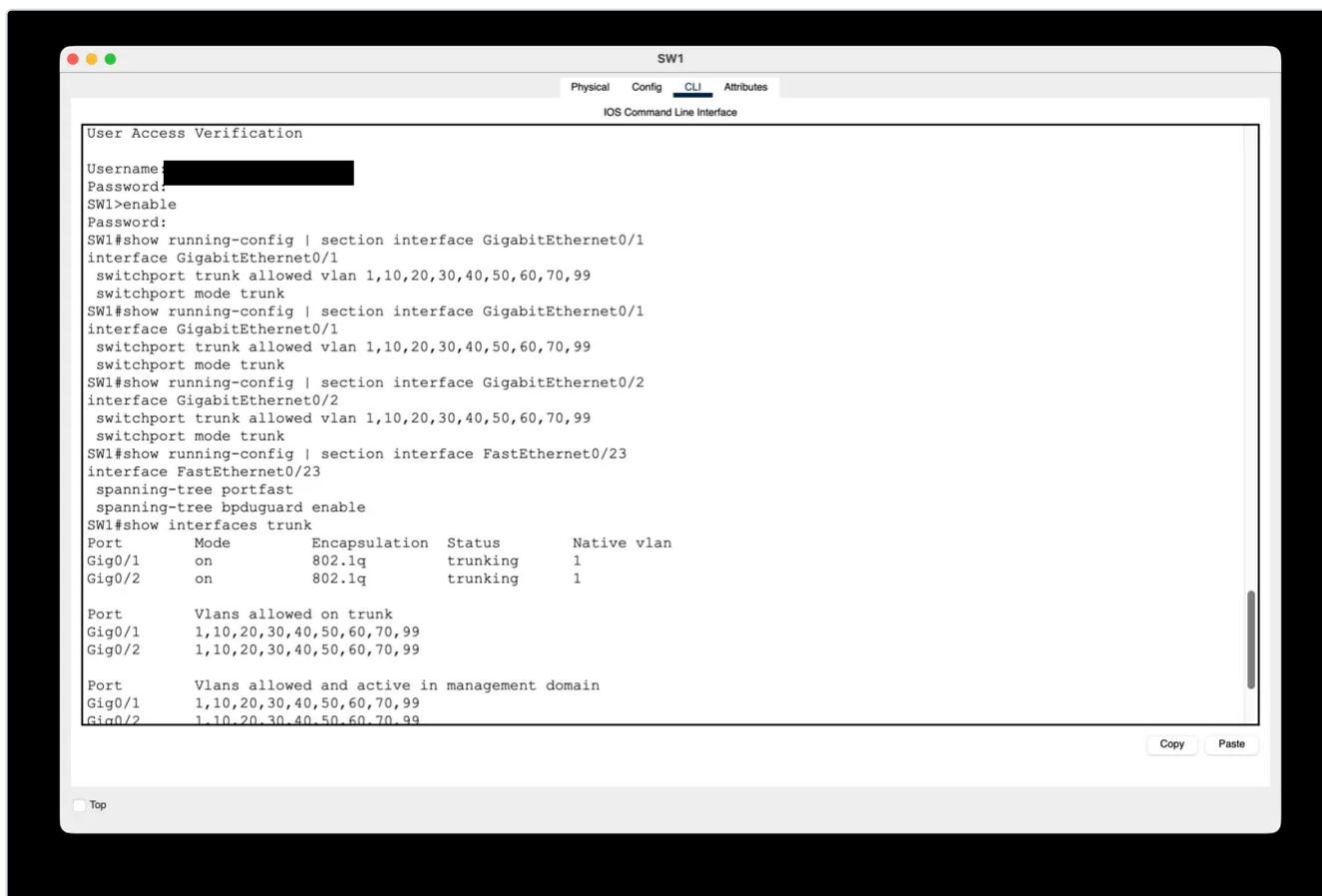
ASA CLI - show nat returns no NAT rules; show access-list reports 0 custom ACLs (only the cached ACL log flows counter); show route reports "Gateway of last resort is not set". Combined with screenshots 1-3, this proves the ASA is in full factory configuration and is not on the security path. Supports finding F-10.

Screenshot 5 - L3-SW login + include enable secret / ntp / logging



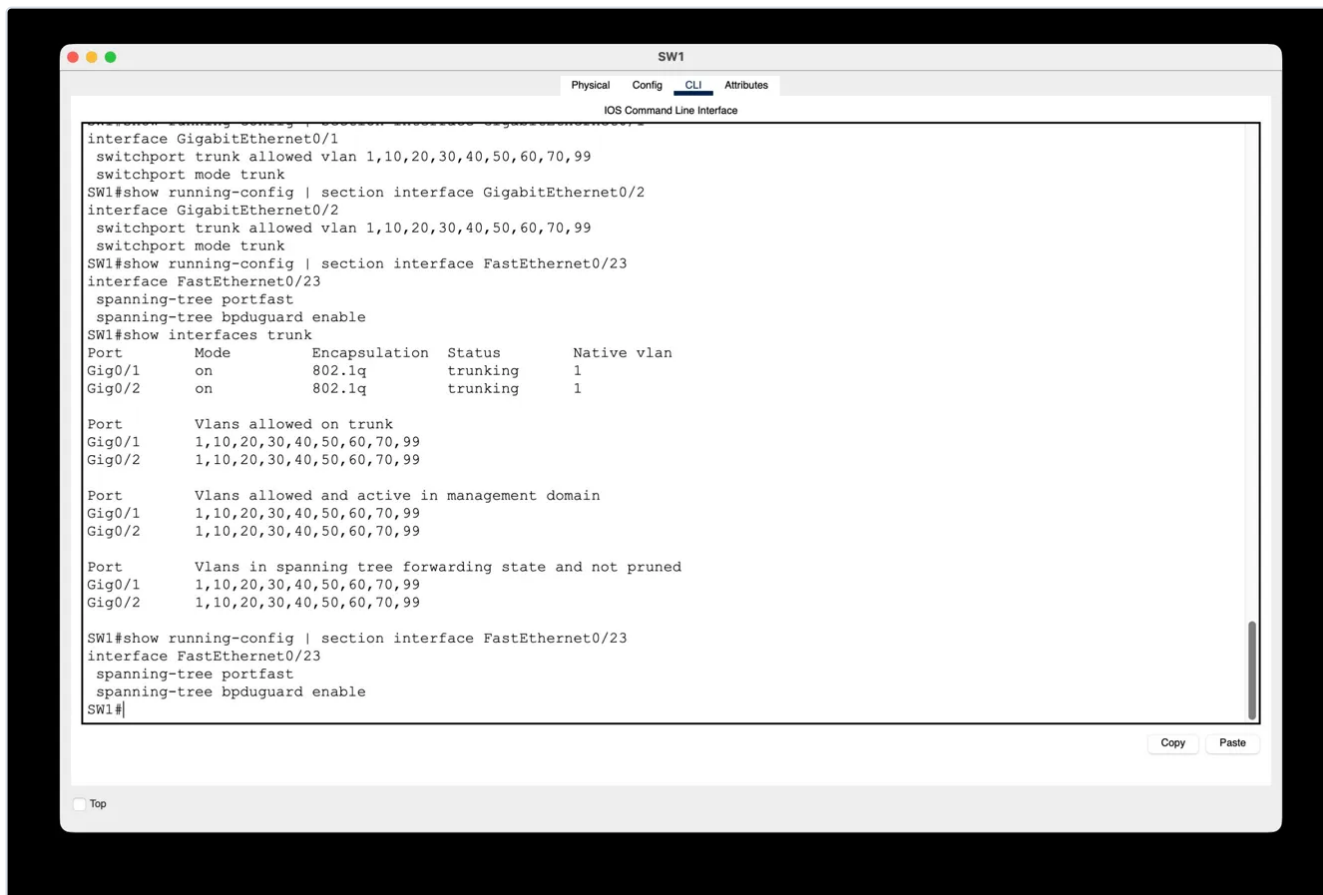
L3-SW CLI - successful login with user-a/user-a (local AAA fallback); show running-config | include enable secret returns the Type 5 MD5 hash \$1\$mERr\$UDABLB/uC5.9xZOBcpF5U.; show running-config | include ntp returns nothing; show running-config | include logging returns nothing. Supports findings F-01 (weak hash type), F-02 (no MFA), F-04 (no NTP, no centralized logging).

Screenshot 6 - SW1 trunk and Fa0/23 configuration



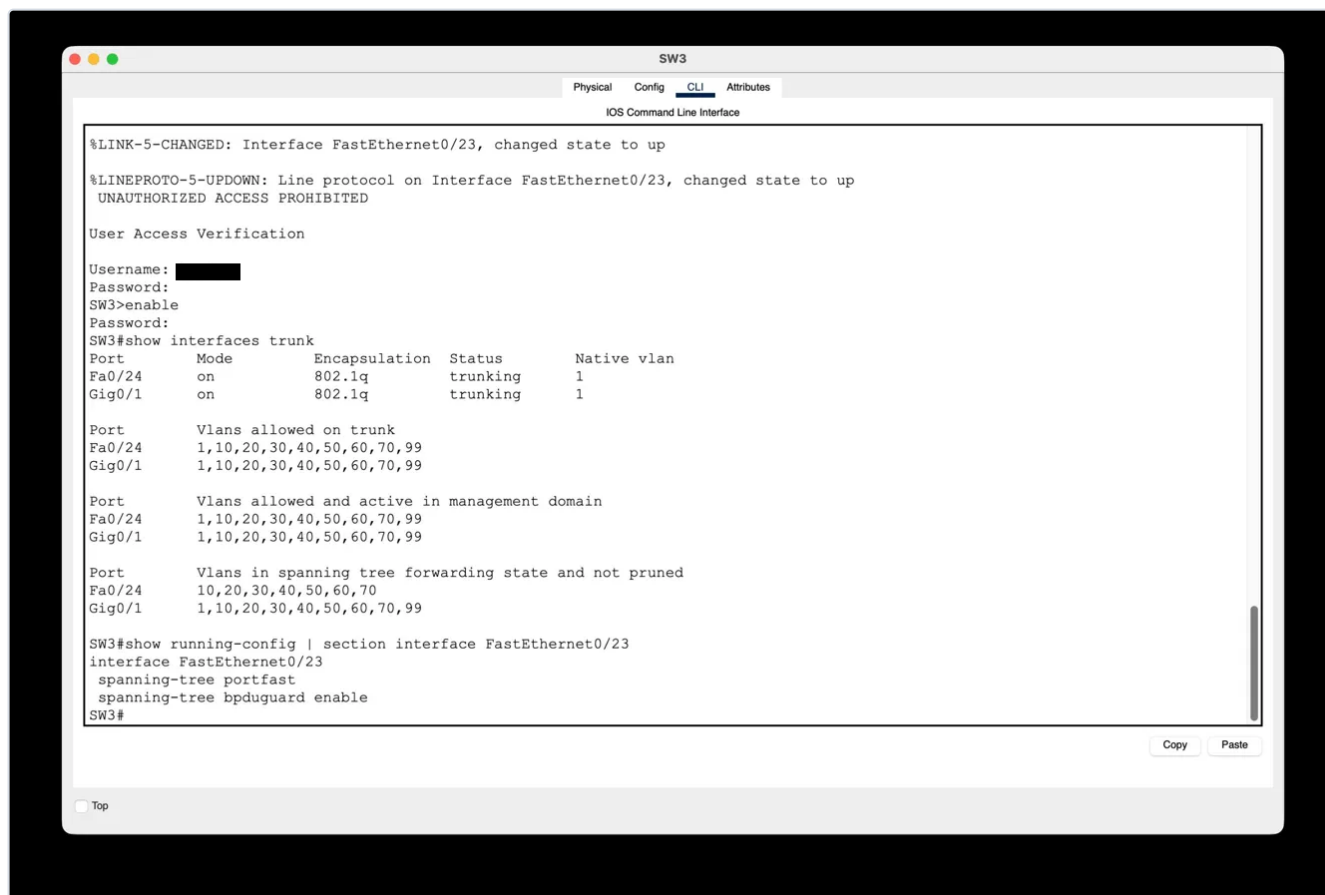
SW1 CLI - show running-config | section interface GigabitEthernet0/1 and Gi0/2: switchport trunk allowed vlan 1,10,20,30,40,50,60,70,99 (correctly restricted). Fa0/23 (printer port) only declares spanning-tree portfast and bpduguard enable - no switchport access vlan, so printer lands in default VLAN 1. Supports findings F-11 (by comparison: SW1 is correctly configured, making SW2 the isolated outlier), F-12 (printer not in dedicated VLAN).

Screenshot 7 - SW1 show interfaces trunk



SW1 CLI - show interfaces trunk: Gig0/1 and Gig0/2 both in 802.1q trunking mode with Native vlan 1 and Vlans allowed on trunk 1,10,20,30,40,50,60,70,99. Proves native VLAN not purged. Supports finding F-13 (native VLAN 1 not moved to an unused VLAN).

Screenshot 8 - SW3 show interfaces trunk + Fa0/23



SW3 CLI - show interfaces trunk on Fa0/24 and Gig0/1 with Native vlan 1 and allowed vlans 1,10,20,30,40,50,60,70,99 (same pattern as SW1). show running-config | section FastEthernet0/23 shows only spanning-tree directives without switchport access vlan. Confirms F-12 is systemic (SW1 + SW3 verified, SW2 assumed by design symmetry); also supports F-11 (SW3 correctly restricted, making SW2 the outlier) and F-13.

Additional empirical checks not captured in this iteration

The following findings were also verified via live CLI inspection during the audit session; the transcripts of the commands and outputs are documented in each finding's Evidence section in Chapter 4. Screenshots can be produced on demand from the same .pkt file by re-running the listed commands.

- F-11 primary evidence on SW2: show running-config | section interface GigabitEthernet0/1 - the switchport trunk allowed vlan, switchport trunk native vlan and switchport nonegotiate commands are absent, making the trunk fully permissive (all 4094 VLANs).
- F-14 and F-15: AAA server, Services → AAA tab - RADIUS service active on port 1645 (while clients configured for TACACS+ on port 49), shared key cisco@123! identical across 4 clients, User Setup containing user-a/user-a, user-b/user-b, user-c/user-c in cleartext.
- F-17: L3-SW, show running-config | section interface Vlan10 and Vlan20 - no ip access-group directive present on any SVI despite the ACLs being defined in running-config (show access-lists confirms definition with zero hit counters).
- F-18: SW1, SW2, SW3, show running-config | section line vty - line vty 5 15 declared as an empty block with no transport input ssh, no login authentication, no exec-timeout. On Cisco IOS 2960 this means Telnet is accepted by default.

Annex B - CyFun 2025 Self-Assessment Toolbox

The scoring artifact supporting all CyFun references throughout this report is the official CCB self-assessment workbook, delivered alongside this document.

File

BeCode_Project4_CyFun2025__v2026_02_20__1_.xlsx - CCB CyFun 2025 Toolbox (Important level), version dated 20 February 2026.

Content

- Six function tabs: GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, RECOVER.
- Documentation and Implementation maturity scores (1-5 scale per the Maturity Levels tab) on every subcategory applicable to the Important assurance level.
- Automatic computation of category-level and function-level maturity averages.
- Summary tab showing the overall posture against the CyFun Conformity Assessment Scheme thresholds ($\geq 3/5$ required on each Key Measure and on the overall average for Important level).

Relation to this report

Every CyFun reference cited in the findings tables (e.g. "PR.AA-01.2 (score 1)", "PR.PS-04.1 (score 2)") corresponds to a cell in this workbook. Opening the file allows direct verification of any individual score and the aggregated function-level maturity used in §7.2 (Current compliance vs CyFun Important target).

How to read it

1. Open the file in Microsoft Excel (cells are protected - this is expected; the workbook operates under CCB accreditation and cells cannot be unprotected).
2. Navigate to the relevant function tab (GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, RECOVER).
3. Locate the subcategory ID referenced in the finding (e.g. PR.AA-01.2).
4. The Documentation Score and Implementation Score columns give the evaluated maturity; the Comments column documents the rationale when applicable.
5. The Summary tab provides the consolidated view used for the compliance posture assessment in Section 7.

- End of report -